سياسة تقنية المعلومات وإدارة الخدمات الرقمية

حزمة سياسات ولوائح القطاع غير الربحي

منصة دفة للتخطيط الاستراتيجي وصناعة السياسات

الإصدار 3.0 | 06 نوفمبر 2026	DAF-ICT-02

التقنية والإعلام والأخلاقيات

نموذج مهني استرشادي

يُستكمل ببيانات الجهة وحقول التخصيص، ويخضع للمراجعة المهنية وقرار الاعتماد والموافقات النظامية اللازمة قبل الاستخدام.

Word + PDF • نموذجًا مطورًا • 4 مجموعات 19

DAF-ICT-02: سياسة تقنية المعلومات وإدارة الخدمات الرقمية

حقل	القيمة
معرف الوثيقة	DAF-ICT-02
العنوان	سياسة تقنية المعلومات وإدارة الخدمات الرقمية
الإصدار	3.0
التاريخ	2026/11/06
المالك	إدارة تقنية المعلومات/الخدمات الرقمية — بالتكامل مع إدارة الحوكمة والسياسات، حزمة دفة المُطوَّرة
الحالة	نموذج مهني استرشادي — لا يصبح معتمدًا إلا بعد استكمال حقول التخصيص وصدور قرار الاعتماد
الجهة المُصدِرة	حزمة دفة (DAF) — منظومة الحوكمة والسياسات للقطاع غير الربحي السعودي
الجمهور المستهدف	مجلس الإدارة، الإدارة التنفيذية، مسؤولو ومنسقو تقنية المعلومات، مالكو الخدمات والأنظمة، مسؤولو الأمن وحماية البيانات، الموارد البشرية، المالية والمشتريات، العاملون والمتطوعون والمقاولون والموردون التقنيون
الإطار الزمني للمراجعة	سنوي (يُراجَع في الربع الأخير من كل سنة ميلادية) أو فور صدور تعديل نظامي أو تقني جوهري
سريان النسخة السابقة	الإصدار 2.0 (2026/11/04) — يُلغى بموجب هذا الإصدار
اللغة	العربية (النسخة العربية هي النسخة المعتمدة؛ أي ترجمة إنجليزية لأغراض مرجعية فقط)
التصنيف	التقنية والإعلام والأخلاقيات — حزمة دفة المُطوَّرة

تعليمات ما قبل المعالجة (PPW)

البند	التفاصيل
PPW-1: مبدأ الامتثال التراتبي	عند التعارض بين هذه السياسة والأنظمة واللوائح والضوابط الصادرة عن الجهات المختصة في المملكة (المركز الوطني لتنمية القطاع غير الربحي، سدايا، الهيئة الوطنية للأمن السيبراني، هيئة الاتصالات والفضاء والتقنية، الهيئة العامة للزكاة والضريبة والجمارك، وزارة الموارد البشرية والتنمية الاجتماعية) تُقدَّم النصوص النظامية النافذة. تُحدَّث هذه السياسة تلقائيًا (دون حاجة لتعديل صريح) بما يوافق أي تعديل نظامي سارٍ، ويُعدّ المرجع الرسمي الصادر من الجهة المختصة حاكمًا في مسائل الاجتهاد

البند	التفاصيل
	التفسيري.
PPW-2: الوضع القانوني للوثيقة	هذه الوثيقة قالب حوكمة معياري (Template) أُعدّ لأغراض التوجيه والتمكين للقطاع غير الربحي السعودي. لا تُغني عن المراجعة القانونية المهنية، ولا عن موافقات الجهات الرسمية عند الحاجة، ولا عن قرار الاعتماد من الجهة المعتمدة لها. يجب استشارة مستشار قانوني مرخص ومستشار أمني مؤهل قبل اعتماد النسخة النهائية أو إجراء أي تعديل جوهري عليها.
PPW-3: آلية التخصيص الإلزامية	جميع الحقول الواردة تحت عناوين «حقول التخصيص» بمختلف البنود (مشار إليها بـ«{{حقل_التخصيص}}» أو جداول الحقول الموسعة (16-1) إلى (16-10)) إلزامية التعبئة قبل الاعتماد الرسمي. لا يجوز اعتماد سياسة تتضمن حقولًا فارغة أو نصوصًا نموذجية غير مخصصة، ويُعدّ عدم اكتمال التخصيص سببًا لعدم جواز العمل بالنسخة.
PPW-4: لغة النص المعتمدة	النص النظامي المعتمد هو النص الصادر باللغة العربية من الجهة المختصة. الترجمات الإنجليزية للأنظمة والضوابط المشار إليها في الحواشي لأغراض الاسترشاد فقط، ولا يجوز الاحتكام إليها في نزاع تفسيري.
PPW-5: العلاقة بوثائق الحزمة	تُقرأ هذه السياسة مع وثائق الحزمة المرتبطة (سياسة أمن المعلومات وحماية البيانات DAF-ICT-01، إطار إدارة المخاطر المعتمد لدى الجهة، سياسة الأخلاقيات والسلوك المهني والنزاهة DAF-ETH-01، سياسة حماية الطفل والبالغين الضعفاء لدى الجهة، اللوائح المالية والأصول، سياسة الموارد البشرية). عند التعارض: تُقدَّم الأنظمة النظامية دائمًا، ثم سياسة أمن المعلومات وحماية البيانات في المسائل الأمنية والخصوصية الخالصة، ثم هذه السياسة في مسائل التشغيل والخدمات الرقمية، ثم اللوائح التفصيلية التابعة في إجراءاتها الخاصة.
PPW-6: التناسب مع حجم الجهة	تُطبق الأحكام بحسب حجم الجهة وطبيعة أنشطتها ومستوى مخاطرها التقنية. الجهة الصغيرة ({{عدد الموظفين}} موظف أو أقل) جائز لها دمج الأدوار الوظيفية بعد توثيق الضابط البديل وضمان عدم اختلال استقلال الرقابة، واستخدام خدمات مشتركة أو سحابية بدل الاستضافة الذاتية، مع بقاء المبادئ والالتزامات النظامية كما هي دون تخفيف.
PPW-7: حجية النسخة الإلكترونية	النسخة المعتمدة هي النسخة الموقعة من الجهة المفوضة والمستوفية لحقول التخصيص. النسخ الإلكترونية الموزعة داخل الجهة لأغراض العمل اليومي، وتُسحب النسخ الملغاة من نقاط الاستخدام مع الاحتفاظ بنسخة أرشيفية وفق جدول مدد الاحتفاظ.
PPW-8: مراقبة التحديثات	يجب على مالك الوثيقة مراقبة التعديلات على: الضوابط الأساسية للأمن السيبراني ECC-2:2024، ضوابط الأمن السيبراني للحوسبة السحابية وضوابط الأنظمة الحرجة، نظام حماية البيانات الشخصية ولائحته ولائحة نقل البيانات خارج المملكة ولواحقها، نظام المعاملات الإلكترونية ولائحته، الإطار التنظيمي لحوسبة السحابة لدى هيئة الاتصالات والفضاء والتقنية، نظام حقوق المؤلف الجديد ولائحته، المعايير التشغيلية الإلزامية للمركز الوطني، وأدلة سدايا وإرشاداتها للذكاء الاصطناعي. تُسجَّل التحديثات في سجل

البند	التفاصيل
	التغييرات.

سجل التغييرات

الإصدار	التاريخ	وصف التغيير	المالك
1.0	2026/11/01	الإصدار الأولي — النسخة الأساسية من حزمة دفة	إدارة الحوكمة والسياسات
2.0	2026/11/04	التحديث الثاني: مواءمة المرجعية مع الضوابط الأساسية للأمن السيبراني ECC-2:2024، وتوسيع الحواشي والمصادر، وإضافة ضوابط أولية للذكاء الاصطناعي والعمل عن بُعد.	إدارة الحوكمة والسياسات
3.0	2026/11/06	إعادة بناء شاملة (إصدار مُعمَّق): (1) هيكلة الوثيقة في خمسة عشر بابًا بدل سبعة أقسام موجزة؛ (2) إضافة باب مستقل متكامل لحوكمة تقنية المعلومات (استراتيجية، موازنة، مخاطر، لجنة توجيهية، مؤشرات أداء)؛ (3) إضافة باب مستقل لإدارة الأصول والتراخيص البرمجية يشمل البرمجيات مفتوحة المصدر ودورة الحياة والتخلص الآمن؛ (4) توسيع باب الهوية والأجهزة ليغطي BYOD والعمل عن بُعد والمراقبة المعلنة وخزنة الأسرار؛ (5) إضافة باب للبريد والشبكات والإنترنت يشمل ضوابط النطاقات (SPF/DKIM/DMARC) والشبكات اللاسلكية؛ (6) إضافة باب للأنظمة والتطبيقات (اعتماد، اختبار، تحديث، ثغرات، أنظمة حرجة)؛ (7) توسيع باب النسخ والاستمرارية ليشمل RTO/RPO وجداول اختبار الاستعادة وخطط التعافي من الكوارث والتعافي السحابي؛ (8) إضافة باب لإدارة التغيير التقني والإصدارات وآليات التراجع؛ (9) إضافة باب للدعم الفني ومستويات الخدمة (SLA/OLA/UC) وإدارة	إدارة الحوكمة والسياسات

الإصدار	التاريخ	وصف التغيير	المالك
		المشكلات؛ (10) إضافة باب للحوادث التقنية يوائم قالب الهيئة الوطنية للأمن السيبراني واشتراطات الإخطار النظامي لحوادث البيانات الشخصية؛ (11) إضافة باب للأرشفة الإلكترونية والسجلات الرقمية يشمل المتطلبات الضريبية؛ (12) إضافة باب مستقل للذكاء الاصطناعي المسؤول: مبادئ سدايا السبعة، حوكمة الأدوات، حماية البيانات، حقوق الملكية الفكرية للمخرجات، وضوابط القرارات المؤثرة على الأفراد؛ (13) إضافة باب للخدمات السحابية والموردين التقنيين بما يوائم إطار هيئة الاتصالات والفضاء والتقنية وضوابط الأمن السيبراني للحوسبة السحابية وضوابط نقل البيانات؛ (14) توسيع حقول التخصيص إلى عشرة جداول؛ (15) إضافة عشر قوائم فحص تشغيلية؛ (16) إضافة ستة نماذج واستمارات (طلب تغيير، تقرير حادث تقني، جرد أصول، بطاقة نظام حرج، موافقة BYOD، محضر اختبار استعادة)؛ (17) تحديث الحواشي والمراجع بالكامل.	

المراجع النظامية والمعيارية

المرجعيات النظامية والتنظيمية السعودية (مرتبة حسب الأهمية)

المرجع	وصفه ودلالة الاستخدام
نظام الجمعيات والمؤسسات الأهلية، المرسوم الملكي رقم (م/8) بتاريخ 1437/02/13هـ كما عُدِّل، ولائحته التنفيذية (قرار مجلس الوزراء 833 بتاريخ 1442/12/24هـ كما عُدِّلت بالقرار 466 بتاريخ 1444/05/25هـ)	النظام الأم للجهة؛ وتحدد اللائحة التنفيذية الالتزامات المرتبطة بالعمليات والسجلات الإلكترونية
قواعد حوكمة الجمعيات والمؤسسات الأهلية (المركز الوطني) كما عُدِّلت	معايير الشفافية والإفصاح التي تستلزم أنظمة وسجلات رقمية موثوقة
المعايير التشغيلية الإلزامية الصادرة عن المركز الوطني (كما تُحدَّث)	تشمل معايير الأنظمة والتقنيات والشفافية المعتمدة للجمعيات والمؤسسات الأهلية

المرجع	وصفه ودلالة الاستخدام
نظام حماية البيانات الشخصية، المرسوم الملكي رقم (م/19) بتاريخ 1443/9/16هـ (2021/09/16م) كما عُدِّل بالمرسوم الملكي رقم (م/148) بتاريخ 1444/9/5هـ (27 مارس 2023م) + اللائحة التنفيذية (القرار الإداري 1445/1516هـ)	حوكمة كل معالجة للبيانات الشخصية: الموافقة، الحد الأدنى من البيانات، الإخطار عن الحوادث، حقوق الأفراد، الإعلان التسويقي المباشر، القرارات الآلية (المادة 24)، ونقل البيانات خارج المملكة (المادة 29)
لائحة نقل البيانات الشخصية خارج المملكة (سدايا، المحدَّثة 2024/09/01م) + البنود التعاقدية المعيارية (SCCs) الأربعة + دليل تقييم مخاطر النقل (2025م) + قواعد إصدار شهادات الاعتماد (2026م)	الأدوات النظامية الملزمة لأي نقل أو إفصاح ببيانات شخصية لجهة خارج المملكة
الدليل الإجرائي لإدارة حوادث اختراق البيانات الشخصية (سدايا)	الإطار التشغيلي لإخطار سدايا بالحوادث خلال (72) ساعة كحد أقصى من العلم بها وتقديم الإخطار الكامل، وإخطار الأشخاص المعنيين عند الاقتضاء
إرشادات ومبادئ الذكاء الاصطناعي المسؤول (سدايا): المبادئ الأخلاقية السبعة للذكاء الاصطناعي	الإطار الوطني الاسترشادي لاستخدام الذكاء الاصطناعي المسؤول
نظام مكافحة الجرائم المعلوماتية، المرسوم الملكي رقم (م/17) بتاريخ 1428/03/08هـ	تجريم الاختراق والإتلاف والتعطيل وانتهاك الخصوصية — أساس الإبلاغ والتعاون عند الجرائم الإلكترونية
نظام المعاملات الإلكترونية، المرسوم الملكي رقم (م/18) بتاريخ 1428/03/08هـ كما عُدِّل بقرار مجلس الوزراء رقم (293) بتاريخ 1445/04/09هـ، ولائحته التنفيذية	الاعتراف بالسجلات والتوقيعات والمعاملات الإلكترونية؛ وإلزام من يوجب عليه قانونًا حفظ سجلات إلكترونية بأداء عمليتي الأرشفة والنسخ الاحتياطي دوريًا بما يكفل حفظ الحقوق
نظام الاتصالات وتقنية المعلومات، المرسوم الملكي رقم (م/106) بتاريخ 1443/11/02هـ، ولائحته التنفيذية (قرار وزاري رقم 1444/13هـ)	تنظيم خدمات الاتصالات وتقنية المعلومات، والرسائل التجارية غير المرغوبة
الإطار التنظيمي لحوسبة السحابة لدى هيئة الاتصالات والفضاء والتقنية (CCRF 2018 ومعدلاته، واللوائح المحدَّثة لتقديم خدمات الحوسبة السحابية السارية منذ أكتوبر 2023م)	إلزام مزودي الخدمات السحابية العاملة في المملكة بالتسجيل لدى الهيئة، وتصنيف بيانات المشتركين (المستويات 1–4)، وقيود إقامة البيانات للمستويات الأعلى حساسية
سياسة «السحابة أولًا» (Cloud First Policy) الوطنية	توجيه وطني معتمد بتقديم خيارات الحوسبة السحابية عند قرارات الاستثمار التقني — لا تلزم الجهات غير الحكومية نظاميًا وتُستخدم استئناسًا
اللائحة التنظيمية لتسجيل أسماء النطاقات تحت النطاق السعودي (sa.) (هيئة الاتصالات والفضاء والتقنية)	شروط تسجيل وإدارة النطاقات الوطنية
ضوابط الاتصالات التجارية عبر وسائل الاتصالات (هيئة الاتصالات والفضاء والتقنية)	ضبط الرسائل التسويقية الجماعية (SMS/البريد) واشتراط الموافقة المسبقة وسهولة إلغاء الاشتراك
الإطار الوطني لإدارة البيانات (المكتب الوطني لإدارة البيانات — الأحكام المؤقتة)	مرجعية وطنية لتصنيف البيانات ومشاركة البيانات الحكومية — تُستخدم استئناسًا في تصنيف بيانات الجهة
نظام حقوق المؤلف الجديد، المرسوم الملكي رقم (م/169) بتاريخ 1448/01/27هـ الموافق أغسطس 2026م، ولائحته التنفيذية (قرار مجلس إدارة الهيئة السعودية للملكية الفكرية ت/33/2026 بتاريخ يوليو 2026م)	حماية البرامج الحاسوبية (بوصفها أعمالًا أدبية) وقواعد البيانات والإجراءات التقنية لحماية الحقوق — أساس أحكام التراخيص البرمجية والملكية الفكرية للمخرجات
نظام ضريبة القيمة المضافة وتعليمات الهيئة العامة للزكاة والضريبة والجمارك + متطلبات الفوترة الإلكترونية (منصة فاتورة)	إلزامية حفظ السجلات والفواتير الضريبية داخل المملكة مدة (10) سنوات، وتوافق أنظمة الفوترة مع متطلبات المرحلتين (الإصدار

المرجع	وصفه ودلالة الاستخدام
	والربط والتكامل) عند انطباقها على أنشطة الجهة
نظام العمل السعودي ولوائحه التنفيذية	أحكام العمل عن بُعد (المادة 43 من اللائحة التنفيذية)، وحدود مراقبة أدوات العمل
نظام مكافحة جرائم الإرهاب وتمويله وتمويل انتشار التسلح كما عُدِّل ولوائحه	واجبات التحقق والإبلاغ ذات الصلة بالأنظمة والمدفوعات الرقمية
نظام الأدلة السعودي (المرسوم الملكي م/43 بتاريخ 1443/07/01هـ)	المعاملة القضائية للأدلة الإلكترونية — سلامة السجل وسلسلة الحيازة

المرجعيات الرقابية الوطنية للأمن السيبراني (التزامية بحسب النطاق)

المرجع	وصفه
الضوابط الأساسية للأمن السيبراني ECC-2:2024 (الهيئة الوطنية للأمن السيبراني)	الحد الأدنى الوطني من متطلبات الأمن السيبراني: (1) حوكمة الأمن السيبراني، (2) الدفاع السيبراني، (3) المرونة السيبرانية، (4) الأمن السيبراني للأطراف الثالثة والحوسبة السحابية، (5) الأمن السيبراني للأنظمة التحكمية الصناعية (ينطبق فقط عند وجود أنظمة تحكمية مثل المباني الذكية)
ضوابط الأمن السيبراني للحوسبة السحابية CCC (الهيئة الوطنية للأمن السيبراني)	توزيع واجبات الأمن بين الجهة ومزود الخدمة السحابية
ضوابط الأمن السيبراني للأنظمة الحرجة CSCC (الهيئة الوطنية للأمن السيبراني)	تنعقد عند تصنيف أنظمة الجهة ضمن الأنظمة الحرجة وفق الهيئة الوطنية
ضوابط خصوصية البيانات الشخصية (الهيئة الوطنية للأمن السيبراني)	إرشادية تتكامل مع نظام حماية البيانات الشخصية
قالب سياسة إدارة الحوادث والتهديدات السيبرانية (الهيئة الوطنية للأمن السيبراني)	القالب الرسمي الوطني المعتمد لهيكلة إدارة الحوادث ودورة حياتها

المرجعيات المعيارية الدولية (استئناسية غير ملزمة)

المرجع	الغرض من الاستئناس
ISO/IEC 27001:2022 وISO/IEC 27002:2022	إدارة أمن المعلومات وأدوات الضبط
ISO/IEC 20000-1	إدارة خدمات تقنية المعلومات (ITSM) — أساس بنود الدعم ومستويات الخدمة
ITIL 4	أفضل الممارسات لإدارة الخدمات: الحوادث، المشكلات، التغيير، التوافر، استمرارية الخدمة
ISO 22301	استمرارية الأعمال — أساس بنود RTO/RPO والتعافي
ISO/IEC 38500 وCOBIT 2019	حوكمة تقنية المعلومات — أساس الباب الثاني
CIS Controls v8 وNIST CSF 2.0	أطر ضبط تقنية عملية استئناسية

المرجع	الغرض من الاستئناس
معايير التحول الرقمي الأساسية V3.0 (هيئة الحكومة الرقمية)	مرجعية استئناسية لتصميم الخدمات الرقمية وقنوات التقديم الإلكترونية عند الارتباط بالجهات الحكومية

تنبيه: جميع المرجعيات الدولية واردة للاستئناس فقط، ولا تُعد التزامًا نظاميًا إلا إذا تبنتها الجهة صراحة أو أوجبها عقد أو مرجع رسمي، ويسود النظام السعودي النافذ عند أي تعارض.

المدخلات المطلوبة وتوقيتها

المدخل	الوصف	التوقيت/التكرار
المعرفة التشغيلية بالسياسة	فهم بنية السياسة والتزاماتها وحقول التخصيص	قبل البدء بأي تخصيص
بيانات الجهة التقنية	الحجم، الفروع، الموظفون، المتطوعون، الأنظمة القائمة، الأجهزة، الاشتراكات السحابية	قبل التخصيص وتحديثها سنويًا
الجرد التقني	قائمة الأصول الحالية (عتاد، برمجيات، تراخيص، حسابات، نطاقات)	قبل التخصيص وجرد كامل سنويًا
تحليل الأعمال (BIA مبسط)	الخدمات الحرجة وأثر توقفها ومدد التحمل المقبولة	قبل تعيين RTO/RPO ومراجعته سنويًا
الحساسية التعاقدية والمالية	العقود مع الموردين التقنيين، اشتراطات التمويل المانح	قبل التخصيص وسنويًا
الإطار الحوكمي	تفويضات الاعتماد، حدود الصلاحيات المالية	قبل البدء
المعرفة بالأنظمة السارية	الأنظمة واللوائح والضوابط السارية في تاريخ التخصيص	قبل البدء
نتائج التدقيق والتقييمات	ملاحظات المراجعين، نتائج اختبارات الاختراق، تقييمات المخاطر	سنويًا وعند التحديث

مخرجات الوثيقة

المخرج	الوصف
نسخة السياسة المعتمدة المخصصة	السياسة بعد اكتمال حقول التخصيص واعتماد الجهة المختصة
سجل الأصول والتراخيص	سجل محدث للأصول والتراخيص البرمجية (نموذج جرد الأصول)
سجل الخدمات والأنظمة الحرجة	بطاقات الأنظمة الحرجة مع RTO/RPO المعتمدة
سجل الأدوات المعتمدة للذكاء الاصطناعي	قائمة الأدوات والأغراض والبيانات المسموح بها
اتفاقيات مستوى الخدمة الداخلية	SLA/OLA معلنة ومقيسة

المخرج	الوصف
جدول مدد الاحتفاظ المعتمد	يُدرج في نظام الأرشفة والسجلات
قوائم الفحص التشغيلية	(10) قوائم جاهزة للاستخدام الميداني
النماذج والاستمارات	(6) نماذج تشغيلية جاهزة
خطة الاستمرارية والتعافي التقنية	مستند فرعي مشتق من الباب السابع

الوثائق ذات العلاقة والجمهور المستهدف

الوثيقة	العلاقة	الجمهور الرئيسي
DAF-ICT-01 سياسة أمن المعلومات وحماية البيانات	تفصيل الضوابط الأمنية والخصوصية التي تبني عليها هذه السياسة	مسؤولو الأمن والخصوصية
إطار إدارة المخاطر — تعدّها الجهة خارج هذه الحزمة	منهجية تقييم ومعالجة المخاطر التقنية	الإدارة التنفيذية
DAF-ETH-01 سياسة الأخلاقيات والسلوك المهني والنزاهة	الاحتيال الإلكتروني والهندسة الاجتماعية والتحويلات الاحتيالية	الجميع
سياسة حماية الطفل والبالغين الضعفاء — تعدّها الجهة خارج هذه الحزمة	حماية بيانات الفئات الضعيفة في الأنظمة الرقمية	العاملون والمتطوعون
اللوائح المالية والأصول	ضوابط الأصول والمشتريات والصرف	المالية والمشتريات
سياسة الموارد البشرية ودليل الموظفين	إقرارات الاستخدام المقبول والخصوصية والعمل عن بُعد	الموارد البشرية

مخطط الوثيقة (بنيتها)

1. تعليمات ما قبل المعالجة (PPW) وسجل التغييرات والمراجع
2. الباب الأول: الأحكام التأسيسية والتعريفات
3. الباب الثاني: حوكمة تقنية المعلومات
4. الباب الثالث: إدارة الأصول والتراخيص البرمجية
5. الباب الرابع: إدارة الهوية والوصول والأجهزة والعمل عن بُعد
6. الباب الخامس: البريد الإلكتروني والشبكات والإنترنت
7. الباب السادس: الأنظمة والتطبيقات
8. الباب السابع: النسخ الاحتياطي والاستمرارية والتعافي
9. الباب الثامن: إدارة التغيير التقني والإصدارات
10. الباب التاسع: الدعم الفني ومستويات الخدمة
11. الباب العاشر: الحوادث التقنية والاستجابة
12. الباب الحادي عشر: الأرشفة الإلكترونية والسجلات الرقمية
13. الباب الثاني عشر: الذكاء الاصطناعي المسؤول
14. الباب الثالث عشر: الخدمات السحابية والموردون التقنيون
15. الباب الرابع عشر: الامتثال والمخالفات والاستثناءات والتصعيد

16. الباب الخامس عشر: المراجعة والتحديث والاعتماد
17. حقول التخصيص الموسعة (جداول متعددة)
18. قوائم الفحص التشغيلية
19. النماذج والاستمارات
20. الحواشي والمراجع

الملخص التنفيذي

تحكم هذه السياسة تشغيل تقنية المعلومات وإدارة الخدمات الرقمية في «{{اسم الجهة}}» من لحظة الاقتناء حتى التقاعد، وتعالج بالتفصيل الحوكمة والأصول والتراخيص والهوية والأجهزة والعمل عن بُعد والبريد والشبكات ودورة حياة الأنظمة والنسخ والاستمرارية وأهداف الاستعادة والتغيير والإصدارات والدعم ومستويات الخدمة والحوادث والأرشفة والذكاء الاصطناعي المسؤول، وتستكملها أبواب للخدمات السحابية والموردين والامتثال والمراجعة.

- وظيفة مرجعية: تلخّص الإطار النظامي الساري (نظام حماية البيانات الشخصية ولائحته ولائحة النقل، نظام المعاملات الإلكترونية، نظام الاتصالات وتقنية المعلومات، الإطار التنظيمي للحوسبة السحابية، نظام حقوق المؤلف الجديد، الضوابط الأساسية للأمن السيبراني ECC-2:2024) في نص تشغيلي واحد.
- وظيفة تشغيلية: تُفصّل لكل بند الأحكام والإجراءات والأدوار والسجلات ومؤشرات الأداء، بحيث تتحول السياسة إلى عمل يومي قابل للقياس والمراجعة.
- وظيفة تمكينية: تمنح الجهة حقول تخصيص مرنة وعشر قوائم فحص وستة نماذج جاهزة تُسرّع الاعتماد والامتثال المستمر.

ملاحظة جوهرية: تنظّم هذه السياسة التشغيل التقني؛ أما الضوابط الأمنية والخصوصية التفصيلية فيحيل إليها إلى سياسة أمن المعلومات وحماية البيانات (DAF-ICT-01) مع الإحالة المستمرة إليها، ولا تُكررها إلا بقدر ما يلزم لاستدامة العمل.

الباب الأول: الأحكام التأسيسية والتعريفات

1.1 الاسم والمرجعية والوضع القانوني

الأحكام:

21. هذه سياسة «{{اسم الجهة}}» لتقنية المعلومات وإدارة الخدمات الرقمية، وتُعدّ وثيقة حوكمة داخلية معتمدة من الجهة المختصة بها وفق صلاحياتها، وتعمل بتكامل مع سياسة أمن المعلومات وحماية البيانات.
22. تخضع «{{اسم الجهة}}» — بحسب شكلها القانوني المعتمد (جمعية أهلية/مؤسسة أهلية/تعاونية) — لنظام الجمعيات والمؤسسات الأهلية ولائحته التنفيذية وقواعد حوكمة المركز الوطني والمعايير التشغيلية الإلزامية الصادرة عنه.
23. النسخة المعتمدة هي النسخة المستوفية لحقول التخصيص والموقعة من الجهة المختصة؛ وأي نسخة إلكترونية موزعة داخل الجهة لأغراض العمل اليومي لا تُعد إلا نسخة عمل.

1.2 الغرض والأهداف

الأحكام:

24. تهدف هذه السياسة إلى تحويل تقنية المعلومات في الجهة من كلفة داعمة إلى قدرة مؤسسية مؤثرة في تحقيق رسالتها، وذلك عبر الأهداف التالية:

الهدف	المؤشر على تحقيقه
ضمان التوافر والسلامة والأمن للأنظمة والخدمات الرقمية	مستويات خدمة معتمدة ومقيسة، واختبارات استعادة ناجحة
توحيد إدارة الأصول والحسابات والتغيير والدعم والموردين	سجلات موحدة وإجراءات معلنة ومؤشرات محققة
رفع الجاهزية للحوادث واستمرارية البرامج والاستعادة الفعلية	خطط مختبرة وRTO/RPO محققة

الهدف	المؤشر على تحقيقه
ضبط العمل عن بُعد والأجهزة الشخصية والخدمات السحابية	موافقات مكتوبة وضوابط مفعلة وإقرارات موقعة
حوكمة استخدام الذكاء الاصطناعي استخدامًا مسؤولًا	سجل أدوات معتمدة وضوابط بيانات ومراجعة بشرية
الامتثال للأنظمة والضوابط الوطنية السارية	سجل التزامات محدث وتقارير امتثال دورية
تمكين الخدمات الرقمية للمستفيدين بكفاءة وشفافية	قنوات رقمية عاملة وإتاحة وصول وقياس رضا

1.3 نطاق التطبيق

الأحكام:

25. الأشخاص: تلزم هذه السياسة العاملين (بأجر وبدون أجر) والمتطوعين والمقاولين والمستشارين والموردين التقنيين وكل من يُمنح وصولًا إلى أنظمة الجهة أو أصولها أو بياناتها، بحسب طبيعة ارتباطه وصلاحياته.
26. الأصول: تشمل نطاقها الأجهزة والخوادم والشبكات وأجهزة الطرفيات والوسائط، والبرمجيات والتراخيص، والأنظمة والتطبيقات والخدمات الرقمية والمواقع والنطاقات، والحسابات والهويات الرقمية، والبيانات بجميع أنواعها، والخدمات السحابية المشتراة، سواء كانت مملوكة للجهة أو مستأجرة أو مشتراة كخدمة.
27. الأماكن: تسري في المقر الرئيسي والفروع والمرافق ومواقع العمل الميدانية وأثناء العمل عن بُعد.
28. القراءة المرجعية: تُقرأ مع سياسة أمن المعلومات وحماية البيانات وإطار إدارة المخاطر وسياسة مكافحة الاحتيال واللوائح المالية. عند التعارض في المسائل الأمنية والخصوصية تُقدَّم سياسة أمن المعلومات وحماية البيانات؛ وعند التعارض مع النص النظامي يُقدَّم النظام دائمًا.

1.4 التعريفات والاختصارات

المصطلح	التعريف المعتمد في الوثيقة
الأصل التقني	كل عنصر له قيمة للجهة ويخضع للإدارة: عتاد، برمجيات، تراخيص، بيانات، حسابات، نطاقات، خدمات سحابية.
سجل الأصول (CMDB)	المستودع المرجعي الموحد لأصول تقنية المعلومات وبياناتها وعلاقاتها.
RTO	الزمن المستهدف لاستعادة الخدمة بعد الانقطاع (Recovery Time Objective).
RPO	الحد الأقصى المستهدف لفقدان البيانات مقاسًا بالزمن (Recovery Point Objective).
مستوى الخدمة (SLA)	مستهدفات معتمدة للتوافر والاستجابة والاستعادة والدعم لخدمة أو فئة طلبات.
الاتفاقية التشغيلية (OLA)	التزام داخلي بين وحدات الجهة يمكّن الوفاء بمستوى الخدمة.
العقد الداعم (UC)	التزام خارجي بمستوى خدمة مع مورد يدعم تقديم الخدمة للمستفيد.
الحساب المميز	حساب يملك صلاحيات إدارية أو وصولًا مؤثرًا ويخضع لرقابة إضافية.
MFA	المصادقة متعددة العوامل.
BYOD	استخدام جهاز شخصي للعمل وفق ضوابط الفصل والتشفير والحذف

المصطلح	التعريف المعتمد في الوثيقة
	والموافقة المكتوبة.
CAB	لجنة مراجعة التغييرات التقنية (Change Advisory Board).
الحادث التقني	حدث غير مخطط يقلل جودة أو توافر خدمة أو يمس أمن البيانات أو الأصول.
الحادث الأمني	حادث يمس سرية أو سلامة أو توافر البيانات أو الأنظمة (اختراق، تصيد، برمجية خبيثة، وصول غير مصرح).
الثغرة	ضعف قابل للاستغلال في نظام أو مكوّن أو إعداد.
الحاوية (الحوسبة)	بيئة معزولة تفصل بيانات العمل عن بيانات الجهاز الشخصي.
SCCs	البنود التعاقدية المعيارية لسدايا لنقل البيانات الشخصية خارج المملكة.
XLA	اتفاقية مستوى التجربة: قياس تجربة المستفيد الفعلية لا الأرقام التقنية وحدها.

الباب الثاني: حوكمة تقنية المعلومات

2.1 مبادئ الحوكمة

الأحكام:

29. المواءمة الاستراتيجية: تُدار تقنية المعلومات كخدمة مؤسسية مرتبطة بأهداف الجهة ورسالتها ومخاطرها واستمرارية برامجها، لا كدعم للأجهزة فقط.
30. الملكية والمساءلة: لكل خدمة وأصل ونظام مالك معلن يتحمل مسؤولية نتيجته؛ ولا يُشغَّل أي نظام أو خدمة دون مالك معتمد.
31. الفصل بين الإعداد والاعتماد والمراجعة: لا يجوز الجمع بين من أعدّ العملية ومن اعتمدها ومن راجع أدلتها متى أخل ذلك باستقلال الرقابة؛ ويجوز للجهة الصغيرة تعدد الأدوار بعد توثيق ضابط بديل ومراجعة دورية.
32. التناسب: تُطبق الضوابط بحجم الجهة ومستوى مخاطرها، دون الإخلال بالالتزامات النظامية.
33. الامتثال التراتبي: الأنظمة النظامية أولًا، ثم سياسة الأمن والحماية، ثم هذه السياسة، ثم اللوائح التفصيلية.
34. الشفافية والقياس: قرارات التقنية والأداء موثقة وقابلة للقياس والمراجعة من الجهات المختصة داخل الجهة وخارجها.
35. التحسين المستمر: تُراجع الخدمات والمستهدفات دوريًا وتُستثمر الدروس المستفادة من الحوادث والتدقيق.

2.2 الأدوار ومصفوفة المسؤوليات

الأحكام:

الدور	المسؤوليات الأساسية	مستوى المساءلة	الأدلة
مجلس الإدارة	اعتماد السياسة والموازنة التقنية السنوية وقبول المخاطر التقنية الجوهرية	مساءلة عليا	محاضر مجلس وقرارات
الإدارة التنفيذية	اعتماد الخطة والموازنة التقديرية وخدمات جديدة وخطط الاستمرارية	مساءلة عليا	خطط وقرارات

الدور	المسؤوليات الأساسية	مستوى المساءلة	الأدلة
منسق/مدير تقنية المعلومات	التشغيل اليومي والأصول والدعم والتغيير والنسخ والتعافي	ملكية الخدمة	سجلات وتقارير
مالك الخدمة/النظام	تحديد المتطلبات والأولوية وقبول التغيير والاستمرارية والرضا	مسؤولية النتيجة	متطلبات وتوقيعات قبول
الأمن/حماية البيانات	مراجعة المخاطر والحوادث والموردين والخصوصية واعتماد ضوابط الأمن	استقلال الرقابة	تقييمات وموافقات
الموارد البشرية	إقرارات الاستخدام المقبول وسياسة العمل عن بُعد وإجراءات الفصل	مسؤولية وظيفية	إقرارات وسجلات
المالية/المشتريات	العقود والتراخيص والتكلفة ومراجعة الموردين	رقابة تعاقدية	عقود ومحاضر مراجعة
المستخدمون	الاستخدام المقبول والإبلاغ الفوري وحماية الأصول والأدلة	مسؤولية فردية	طلبات وإقرارات وبلاغات

قاعدة البديل: عند غياب مسؤول التقنية أو انتهاء علاقته تُفعَّل خطة البدائل المعلنة (شخص بديل معتمد أو مورد عقد دعم) خلال {{مدة تفعيل البديل}} يوم عمل، وتُوثق في محضر تسليم.

2.3 الاستراتيجية والتخطيط السنوي

الأحكام:

36. تعتمد الإدارة التنفيذية، بعد موافقة مجلس الإدارة بحسب حدود الصلاحيات، خطة سنوية لتقنية المعلومات تتضمن كحد أدنى: احتياجات الوحدات، ودورة حياة الأصول واستبدالها، والأمن وحماية البيانات، والتراخيص والتجديدات، والنسخ الاحتياطي والاستمرارية، والمشاريع والأنظمة الجديدة، والموردون، والموازنة التقديرية، ومؤشرات الخدمة.
37. تُوثق أولويات التنفيذ وفق أربعة معايير مرجحة: أثر الخدمة على المستفيد، والمخاطر (تقنية/نظامية)، والامتثال، والتكلفة الكلية للملكية (TCO) لا السعر الأولي.
38. تُراجع الخطة في منتصف العام وتُحدَّث عند حدوث تغيير جوهري (نظامي، تنظيمي، تقني).

الإجراءات التشغيلية:

الخطوة	الوصف	المسؤول	السجل/الوثيقة	مؤشر الأداء
2.3.1	جمع احتياجات الوحدات عبر نموذج موحد قبل نهاية الربع الثالث	مالكو الخدمات	نماذج الاحتياج	اكتمال الجمع من 100% من الوحدات
2.3.2	إعداد مسودة الخطة والموازنة التقديرية	منسق التقنية	مسودة الخطة	اعتماد ≥ 60 يومًا من الجمع
2.3.3	مراجعة الأمن والخصوصية للخطة	الأمن/حماية البيانات	تقييم معالج	100% من البنود الجديدة مقيّمة
2.3.4	عرض الخطة على	الإدارة التنفيذية	محضر	اعتماد قبل بداية السنة

الخطوة	الوصف	المسؤول	السجل/الوثيقة	مؤشر الأداء
	الإدارة التنفيذية ثم مجلس الإدارة وفق الصلاحيات			
2.3.5	متابعة تنفيذ الخطة ربع سنويًا ورفع تقرير الانحرافات	منسق التقنية	تقارير ربعية	تقرير كل 3 أشهر

2.4 الموازنة والتكلفة

الأحكام:

39. تُعد موازنة تقنية المعلومات سنويًا ببندين منفصلين على الأقل: تشغيلية (اشتراكات، صيانة، دعم، تراخيص، اتصالات) ورأسمالية (أجهزة، أنظمة جديدة، مشاريع).
40. تُراجع الانحرافات الجوهرية (أكثر من {{نسبة انحراف البند}}% من البند) وتُفسَّر وتُعالج قبل إغلاق السنة.
41. لا يجوز الالتزام بمصروف تقني يتجاوز حد صلاحية المعتمد إلا بموافقة الجهة الأعلى وفق مصفوفة الصلاحيات المعتمدة.

2.5 إدارة المخاطر التقنية

الأحكام:

42. تُدار المخاطر التقنية ضمن إطار إدارة المخاطر المعتمد لدى الجهة، ويُنشأ سجل مخاطر تقنية يُحدَّث ربع سنويًا.
43. تُقيَّم المخاطر التقنية قبل: اقتناء نظام جديد، التعاقد مع مورد تقني جوهري، نقل بيانات خارج المملكة، تفعيل أداة ذكاء اصطناعي، أو تنفيذ تغيير جوهري.
44. يقبل مجلس الإدارة المخاطر عالية الأثر (كما حُددت في إطار المخاطر) ويوثق القبول المعالَج.

2.6 اللجنة التوجيهية لتقنية المعلومات

الأحكام:

45. تُشكل لجنة توجيهية برئاسة {{جهة رئاسة اللجنة التوجيهية}} وتضم: منسق التقنية، ممثل الإدارة التنفيذية، مسؤول الأمن/حماية البيانات، ممثل المالية، وممثل الموارد البشرية عند الحاجة، ومالكي الخدمات عند مناقشة خدماتهم.
46. تنعقد كل {{دورية اجتماعات اللجنة التوجيهية}} وتختص ب: أولويات الخطة، اعتماد التغييرات الجوهرية، مراجعة مستويات الخدمة والحوادث الجوهرية، قبول المخاطر المتوسطة، ومتابعة توصيات التدقيق.

2.7 مؤشرات الأداء والتقارير

الأحكام:

47. تعتمد الجهة المستهدفات التشغيلية التالية (استرشادية وتُعدَّل بعد قياس خط الأساس بحجم العمل والمخاطر):

المؤشر	طريقة القياس	الدورية	المستهدف الاسترشادي
توافر الخدمات الحرجة	وقت التوافر ÷ الوقت المتفق عليه مع استثناء الصيانة المعتمدة	شهريًا	≥ 99.5% (بحسب مستوى الخدمة لكل نظام)
الاستجابة والاستعادة للدعم	التذاكر المستوفاة للمستهدف ÷ إجمالي التذاكر	شهريًا	≥ 90%
نجاح اختبارات الاستعادة	اختبارات تحقق RTO/RPO ÷ الاختبارات المخططة	نصف سنوي	100%

المؤشر	طريقة القياس	الدورية	المستهدف الاسترشادي
الثغرات الحرجة المتأخرة	الثغرات الحرجة بعد موعد المعالجة	أسبوعيًا	صفر
مراجعة الصلاحيات	الأنظمة المُراجَعة في موعدها ÷ المستحقة	ربع سنوي	100%
نجاح مهام النسخ	مهام ناجحة ÷ إجمالي المهام المنفذة	أسبوعيًا	≥ 98%
الأعطال المتكررة	أعطال مرتبطة بسبب جذري مفتوح ÷ إجمالي الأعطال	شهريًا	اتجاه تنازلي
رضا المستفيدين من الدعم	تقييمات إيجابية ÷ التقييمات المستلمة	ربع سنوي	≥ 85%

48. تُرفع تقارير الأداء إلى الإدارة التنفيذية شهريًا (ملخص) وإلى مجلس الإدارة ربع سنويًا، وتُحلل الانحرافات الجوهرية ويُحدد لكل منها مسؤولًا وتاريخ معالجة.

الباب الثالث: إدارة الأصول والتراخيص البرمجية

3.1 تعريف الأصول وتصنيفها

الأحكام:

49. كل عنصر تقني له قيمة للجهة — ماديًا أو معلوماتيًا — يُعدّ أصلًا خاضعًا لهذه السياسة، ولا يجوز تشغيل أصل خارج سجل الأصول.
50. التصنيف المعتمد:

الفئة	أمثلة	مسؤول السجل
عتاد وأجهزة	خوادم، حواسيب، طابعات، أجهزة شبكية، أجهزة عرض	التقنية
برمجيات وأنظمة	تطبيقات جاهزة، أنظمة مخصصة، أنظمة تشغيل	التقنية/مالك النظام
تراخيص ومقاعد	اشتراكات سنوية، تراخيص مستخدمين	التقنية/المشتريات
بيانات ومعلومات	قواعد بيانات، سجلات مستفيدين، ملفات مؤسسية	مالك البيانات
هويات وحسابات	نطاقات، حسابات إدارية، حسابات خدمات	التقنية
خدمات سحابية	بيئات استضافة، تخزين، بريد سحابي	التقنية/المشتريات

3.2 سجل الأصول وسجل التكوين

الأحكام:

51. يُنشأ سجل أصول موحد (ويكون سجل تكوين CMDB عند حاجة الجهة) يحتوي كحد أدنى على البيانات التالية لكل فئة:

نوع الأصل	الحد الأدنى للسجل	دورية المراجعة
أجهزة وخوادم	الرقم الأصلي، المالك، الموقع، الطراز، الرقم التسلسلي، تاريخ الاقتناء، الحالة، الضمان	جرد سنوي وعند النقل
أنظمة وتطبيقات	المالك، الإصدار، البيئة، المورد، نوع البيانات، المستخدمون، أهداف الاستعادة	ربع سنوي وعند التغيير
حسابات وتراخيص	النوع، المقاعد، المستفيدون، تاريخ الانتهاء، التكلفة، مسؤول التجديد	ربع سنوي
شبكات ونطاقات	النطاق، المالك، مسجل النطاق، شهادات الأمان، الجهات المرتبطة، تاريخ الانتهاء	شهريًا وقبل أي انتهاء
موردون سحابيون	الخدمة، مواقع الاستضافة، نوع البيانات، المقاولون من الباطن، اتفاقية الخدمة، نموذج النسخ	سنويًا وعند العقد
إعدادات مرجعية	النسخة، الإعداد، التغيير، المعتمد، طريقة الاستعادة	بعد كل تغيير جوهري

52. تُستخدم أرقام أصول فريدة وملصقات تعريف لا تكشف معلومات حساسة.
53. تُحفظ إعدادات التكوين الآمن وخطوط الأساس في مستودع مقيد الوصول مع توثيق النسخ.

الإجراءات التشغيلية:

الخطوة	الوصف	المسؤول	السجل/الوثيقة
3.2.1	إدراج أي أصل جديد في السجل قبل التشغيل أو عنده	التقنية	سجل الأصول
3.2.2	الجرد السنوي الميداني ومطابقة السجل بالفعل	لجنة الجرد	محضر جرد (نموذج جرد الأصول)
3.2.3	معالجة فروقات الجرد وتوثيقها خلال {{مدة معالجة فروقات الجرد}} يومًا	التقنية	محضر معالجة
3.2.4	مراجعة التراخيص والنطاقات قبل انتهائها بـ {{مدة التنبيه قبل انتهاء الترخيص}} يومًا	التقنية/المشتريات	سجل تنبيهات

3.3 دورة حياة الأصول

الأحكام:

54. تمر الأصول بمراحل: اقتناء (موافقة وفق مصفوفة الصلاحيات)، تشغيل (تسجيل وتهيئة آمنة)، صيانة (تحديث وإصلاح)، نقل (موافقة ومحضر)، إحلال (وفق دورة الاستبدال المعتمدة: {{دورة استبدال الحواسيب المكتبية}} سنوات للمكتبية و{{دورة استبدال الأجهزة المحمولة}} سنوات للمحمولة استرشاديًا)، تقاعد (إتلاف أو إعادة تخصيص أو بيع أو تبرع بموافقة الجهة المختصة).

3.4 التراخيص البرمجية

الأحكام:

55. لا يجوز استخدام برمجيات مقرصنة أو مخالفة لشروط الترخيص، ولا تجاوز عدد المقاعد المشتراة، ولا استخدام الترخيص في غير نطاقه.
56. يُحظر تثبيت البرمجيات على أجهزة الجهة أو حساباتها دون موافقة منسق التقنية مع مراعاة الترخيص.
57. تُدار التراخيص في سجل مركزي يوضح: المنتج، المالك القانوني للترخيص، عدد المقاعد، المستخدمون المعينون، تاريخ الانتهاء، ومسؤول التجديد.
58. يُجرى تدقيق تراخيص سنويًا (مراجعة العقود والمقاعد والاستخدام) ويُوثق في محضر.
59. تُراعى أحكام نظام حقوق المؤلف الجديد (المرسوم الملكي م/169 لعام 1448هـ الموافق 2026م) ولائحته التنفيذية في جميع أعمال الاقتناء والاستخدام والنسخ والتخزين.

3.5 البرمجيات مفتوحة المصدر

الأحكام:

60. يجوز استخدام البرمجيات مفتوحة المصدر بعد مراجعة تقنية وأمنية، ومراجعة شروط الترخيص للتأكد من عدم إلزام الجهة بإفصاح شيفرتها الخاصة (تراخيص النوع القوي copyleft).
61. تُسجل المكونات مفتوحة المصدر المدمجة في الأنظمة المخصصة ضمن سجل الأصول، وتُراجع دوريًا من حيث الثغرات والتحديثات.

3.6 الوسائط القابلة للنقل

الأحكام:

62. تُقيّم الوسائط الخارجية (أقراص، ذواكر) قبل الاستخدام وتُفحص ضد البرمجيات الخبيثة، وتُشفر إذا حملت بيانات الجهة.
63. تُمنع الوسائط الشخصية على الأنظمة الحساسة إلا باستثناء محدد ومسجل وموافق عليه.
64. تُنقل الأجهزة والوسائط في حقائب آمنة ولا تُترك في مركبات أو أماكن عامة، ويُبلَّغ فورًا عن الفقدان مع بيان الأصل والبيانات المحتملة.

3.7 إعادة التخصيص والتخلص من الأصول

الأحكام:

65. لا يُعاد تخصيص جهاز أو وسيط ولا يُباع ولا يُتبرع به إلا بقرار من الجهة المختصة وفق اللوائح المالية، مع محضر يوضح المصير (تحويل، بيع، تبرع، إتلاف).
66. قبل أي تسليم تُمحى بيانات الجهة بشكل آمن يمنع الاسترداد (مسح معتمد، أو تشفير ثم تهيئة، أو إتلاف فيزيائي للوسائط المعطوبة)، وتُوثق شهادة المحو أو الإتلاف.
67. عند بيع أو تبرع أو إتلاف أصل يحمل بيانات شخصية أو سرية يُطبق بند محو البيانات ويُوقع المستلم على إقرار استلام.

الباب الرابع: إدارة الهوية والوصول والأجهزة والعمل عن بُعد

4.1 إنشاء الحسابات والهوية الرقمية

الأحكام:

68. تُنشأ جميع الحسابات بناء على طلب معتمد يحدد: الاسم، الدور الوظيفي، الأنظمة المطلوبة، مستوى الصلاحية، المدة، والمسؤول عن الطلب.
69. تُربط الحسابات بهوية فردية لكل شخص؛ ولا تُستخدم حسابات عامة مشتركة، وتُستثنى حسابات الخدمات الفنية (Service Accounts) بشرط توثيقها ومراقبتها وإخضاعها لأقل صلاحية.
70. تُراجع الحسابات عند: النقل الوظيفي، تغيير الدور، انتهاء التكليف، أو انتهاء العلاقة.

الإجراءات التشغيلية:

الخطوة	الوصف	المسؤول	السجل/الوثيقة	مؤشر الأداء
4.1.1	تقديم طلب فتح حساب من المدير المباشر	طالب الحساب	نموذج الطلب	زمن الاستجابة ≤ {{زمن إنشاء الحساب}} يوم عمل
4.1.2	تحقق التقنية من الحد الأدنى والتزام أقل صلاحية	التقنية	سجل الموافقة	100% من الحسابات بموافقة
4.1.3	إنشاء الحساب وتفعيل MFA	التقنية	سجل الإنشاء	تفعيل MFA 100% للحسابات البعيدة والمميزة
4.1.4	إبلاغ المستخدم وإقراره بالاستخدام المقبول	التقنية/الموارد البشرية	إقرار موقع	إقرار قبل أول استخدام

4.2 الصلاحيات وإدارة الوصول

الأحكام:

71. تُطبق قاعدة أقل صلاحية: لا يمنح المستخدم إلا ما يحتاجه لأداء دوره.
72. يُفصل بين المهام الحرجة (مثل: من يعتمد الصرف لا يدير النظام المحاسبي وحده) وفق سياسات الفصل المالي.
73. تُراجع صلاحيات المستخدمين والامتيازات دوريًا كل {{دورية مراجعة الصلاحيات}} (ولا تتجاوز ربع سنة)، وبعد أي نقل أو تغيير وظيفي.
74. تُعطل الحسابات فور انتهاء العمل أو العلاقة ولا تُؤجل، وتُراجع ملفات الموردين والمفاتيح والرموز السرية المرتبطة.

4.3 الحسابات المميزة والأسرار

الأحكام:

75. تُفصل حسابات إدارة النظام عن الاستخدام اليومي؛ ولا يستخدم المسؤول حسابه الإداري للبريد أو التصفح.
76. تُفرض MFA على الحسابات المميزة والوصول البعيد والبريد الإلكتروني وفق تقييم الأثر.
77. تُسجل العمليات المميزة (إنشاء حسابات، تغيير صلاحيات، وصول إلى بيانات حساسة) وتُراجع دوريًا.
78. تُدار أسرار الوصول (كلمات مرور الخدمات، مفاتيح API، الشهادات) في خزنة أسرار معتمدة، ولا تُحفظ في رسائل أو جداول أو ملفات نصية مكشوفة أو مستودعات برمجية.
79. تُدار كلمات المرور وفق السياسة المعتمدة {{سياسة كلمات المرور}} (الحد الأدنى للطول والتعقيد ودورة التغيير وعدم إعادة الاستخدام).

4.4 الأجهزة المؤسسية

الأحكام:

80. لا تُشغل أجهزة الجهة إلا بإعدادات أساس آمن تشمل كحد أدنى: تشفير أقراص النظام، وقفل تلقائي للشاشة خلال {{مدة قفل الشاشة}} دقيقة، برمجية مكافحة خبيثة محدثة، تحديثات نظام التشغيل والتطبيقات، وحساب مستخدم قياسي غير إداري.
81. تُسجل جميع أجهزة الجهة في سجل الأصول وتوثق حالتها ومستخدموها، وتُدار مركزيًا عند توفر أدوات إدارة الأجهزة (MDM/UEM).
82. تُراقب أجهزة العمل لأغراض حماية أمن الجهة بعد إفصاح مسبق وموثق للمستخدمين، ولا تمتد المراقبة إلى الحسابات أو البيانات الشخصية للمستخدم خارج نطاق العمل، ويُحظر استخدام بيانات المراقبة خارج الغرض المعلن.

4.5 الأجهزة الشخصية (BYOD)

الأحكام:

83. يُشترط للسماح باستخدام جهاز شخصي للعمل: موافقة مكتوبة موقعة (نموذج موافقة BYOD)، وتفعيل ضوابط الفصل (حاوية عمل مشفرة أو حل معتمد يفصل ملفات العمل)، وتشفير بيانات العمل، وإدارة الوصول عبر MFA، وتثبيت حل الأمن المطلوب.
84. تملك الجهة سلطة الحذف الانتقائي لبيانات العمل فقط عند الفقد أو السرقة أو انتهاء العلاقة؛ ولا تملك حذف البيانات الشخصية للمستخدم، ويُوثق إقرار إتمام الحذف الانتقائي عند انتهاء العلاقة.
85. لا يجوز عبر الجهاز الشخصي: الوصول إلى الأنظمة المصنفة سرية أو شديدة الحساسية، أو تخزين نسخ محلية من بيانات المستفيدين أو المتبرعين، إلا باستثناء معتمد ومسجل.
86. يتحمل المستخدم مسؤولية حماية جهازه (قفل، تحديث) والإبلاغ الفوري عن فقدانه.

4.6 العمل عن بُعد

الأحكام:

87. يُنظم العمل عن بُعد وفق نظام العمل ولائحته التنفيذية (ومنها أحكام المادة (43) من اللائحة التنفيذية) وسياسة الجهة، باتفاق مكتوب يحدد: ساعات العمل، وقنوات التواصل، وأدوات العمل المعتمدة، ومسؤوليات السلامة.
88. تقنيًا: يُشترط للعمل عن بُعد جهاز مؤسسي معتمد أو جهاز شخصي مفعّل BYOD، ودخول عبر قناة آمنة معتمدة (VPN/بوابة وصول آمنة)، وتفعيل MFA، وعدم مشاركة الجلسات أو ترك الأجهزة مفتوحة، وبيئة عمل منزلية لا يطلع عليها غير المخولين.
89. لا تُستخدم شبكات عامة مفتوحة للوصول إلى الأنظمة الحساسة إلا عبر قناة آمنة معتمدة، وتُمنع مشاركة الهاتف كموزع إنترنت (Hotspot) لأجهزة غير معتمدة دون ضبط معلن.
90. تُمنع الطباعة المنزلية للمستندات شديدة الحساسية، وتُجمع المطبوعات فورًا من أجهزة الطباعة المشتركة.

الباب الخامس: البريد الإلكتروني والشبكات والإنترنت

5.1 البريد الإلكتروني المؤسسي

الأحكام:

91. يُستخدم البريد المؤسسي ({{نطاق البريد المؤسسي}}) للمراسلات الرسمية والعمل؛ ولا يجوز إدارة أعمال الجهة عبر بريد شخصي.
92. تُفعّل على البريد كحد أدنى: المصادقة متعددة العوامل، والحماية من التصيد والرسائل المزعجة، والأرشفة، والنسخ الاحتياطي، وتصفية المرفقات الخطرة.
93. تُمنح صناديق البريد للمتطوعين والمقاولين بحسب الحاجة وبمدة محددة، وتُعطل عند انتهاء العلاقة.
94. يُراعى في المراسلات حظر الإعلان التسويقي المباشر دون موافقة مسبقة وفق نظام حماية البيانات الشخصية، وضوابط الرسائل التجارية عبر وسائل الاتصال.

5.2 التصدي للتصيد والاحتيال عبر البريد

الأحكام:

95. تُضبط سجلات النطاقات SPF وDKIM وDMARC وفق البنية المعتمدة لمنع انتحال نطاق الجهة في الرسائل الاحتيالية، وتراجع النطاقات والشهادات والتنبيهات دوريًا.
96. تُنفذ برامج توعية دورية بالتصيد، ويُبلَّغ عن الرسائل المشبوهة عبر القناة الرسمية ({{قناة الإبلاغ عن التصيد}}).
97. تُطبق قواعد التحقق من طلبات التحويل المالي الواردة عبر البريد (تحقق هاتفي أو بقناة ثانية مع الجهة الطالبة) وفق سياسة مكافحة الاحتيال، ولا يعتمد أي طلب تغيير بيانات حساب بنكي أو تحويل بناءً على رسالة بريد وحدها.

الإجراءات التشغيلية:

الخطوة	الوصف	المسؤول	السجل/الوثيقة
5.2.1	ضبط ومراجعة SPF/DKIM/DMARC وشهادات النطاق ربع سنويًا	التقنية	سجل مراجعة

الخطوة	الوصف	المسؤول	السجل/الوثيقة
5.2.2	محاكاة تصيد توعوية على الأقل مرة سنويًا	الأمن/التقنية	تقرير نتائج
5.2.3	التحقق ثنائي القناة من طلبات التحويل والتغيير البنكي	المالية/التقنية	سجل تحقق
5.2.4	احتواء رسالة تصيد مؤكدة: حذف من الصناديق، حظر المرسل، فحص النقرات	التقنية	تقرير حادث

5.3 أسماء النطاقات والشهادات الرقمية

الأحكام:

98. تُسجل نطاقات الجهة باسمها القانوني المسجل وبيانات تواصل رسمية (لا بيانات شخصية لموظف)، وتوثق في سجل الأصول، وتلتزم بأحكام اللائحة التنظيمية لتسجيل أسماء النطاقات تحت النطاق السعودي (.sa) عند استخدامه.
99. تُجدد النطاقات والشهادات الرقمية قبل انتهائها بمدة لا تقل عن {{مدة التنبيه قبل انتهاء النطاق}} يومًا، وتُحدد مسؤولية التجديد في سجل النطاقات.
100. لا تعتمد خدمات نطاقات مجانية للنطاقات الحرجة، وتُفعّل قفل النقل (Transfer Lock) لنطاقات الجهة.

5.4 استخدام الإنترنت المقبول

الأحكام:

101. تُستخدم أنظمة وأجهزة الجهة وخدمات الإنترنت المخصصة لها في الأغراض الوظيفية المصرح بها فقط.
102. يُمنع الوصول إلى المحتوى المخالف للأنظمة والآداب والشريعة أو المهدد لأمن الجهة، وتُطبق سياسات التصفية بحسب طبيعة عمل الجهة مع سجل مراجعة مقيد الوصول.
103. تُراجع سياسة الاستخدام المقبول سنويًا ويوقع عليها الموظفون الجدد والمتطوعون والمقاولون قبل منح الوصول.

5.5 الشبكات الداخلية

الأحكام:

104. تُفصل الشبكات منطقيًا (وفيزيائيًا عند الحاجة): شبكة العمل، وشبكة الضيوف، وشبكة الخوادم، وبيئات التطوير والاختبار.
105. تُستخدم جدر الحماية وبروتوكولات آمنة ومراقبة للمنافذ والخدمات، وأي تغيير على بنية الشبكة يمر عبر إجراءات إدارة التغيير (الباب الثامن).
106. يُمنع توصيل أجهزة غير معتمدة أو موجهات شخصية بشبكة العمل؛ وتُتيح شبكة الضيوف لأجهزة الزوار بصلاحيات محدودة وعزل كامل عن شبكة العمل.
107. تُراجع قواعد جدر الحماية والمنافذ المفتوحة نصف سنويًا وتُغلق غير المستخدمة.

5.6 الشبكات اللاسلكية

الأحكام:

108. تُشفر شبكات الجهة اللاسلكية بمعيار WPA2/WPA3 على الأقل، وتُفصل شبكة الضيوف اللاسلكية عن شبكة العمل اللاسلكية.
109. تُدار كلمات مرور الشبكات اللاسلكية كأصول سرية: تغيير دوري، وتسليم مقيد للضيوف عبر قناة منفصلة.

الباب السادس: الأنظمة والتطبيقات

6.1 دورة حياة النظام

الأحكام:

110. تمر الأنظمة والتطبيقات بدورة حياة موثقة: حاجة ودراسة، اعتماد مبدئي، اقتناء أو تطوير، اختبار، إطلاق وقبول، تشغيل وصيانة، تحديث، إحلال أو إيقاف وأرشفة.

111. لا يُشغَّل نظام ولا يُطلق للإنتاج دون استكمال: التسجيل في سجل الأصول، وتحديد مالك معتمد، وتقييم أمن وخصوصية معتمد، وخطة نسخ واستمرارية.

6.2 اعتماد واقتناء الأنظمة

الأحكام:

112. قبل اقتناء أي نظام أو خدمة رقمية أو اشتراك، تُراجع المتطلبات التالية وتُوثق في وثيقة دراسة معتمدة: الغرض والحاجة، والأمن وحماية البيانات، والاستمرارية، والتكامل مع الأنظمة القائمة، وشروط الترخيص، والتكلفة الكلية للملكية، والاعتمادية على المورد وقابلية الخروج، والقيمة المضافة للمستفيد.

113. الأنظمة المتصلة بالمالية أو التي تنتج مستندات نظامية (فواتير، عقود، إيصالات) تُراجع من حيث توافقها مع متطلبات الفوترة الإلكترونية والأرشفة النظامية قبل الاعتماد.

114. لا تُعتمد الأنظمة التي تتطلب بيانات شخصية فوق الحد الأدنى اللازم، أو لا توفر وسائل تمكين الأفراد من حقوقهم (الاطلاع، التصحيح، الحذف)، أو لا تحدد مواقع معالجة البيانات وضوابط نقلها.

الإجراءات التشغيلية:

الخطوة	الوصف	المسؤول	السجل/الوثيقة
6.2.1	تقديم طلب النظام من مالك العملية المعنية	مالك الخدمة	طلب اقتناء
6.2.2	دراسة فنية وتكلفة وبدائل (اشتراك/تطوير/مشتركة)	التقنية/المالية	دراسة مقارنة
6.2.3	تقييم أمن وخصوصية معتمد (حجم البيانات، المواقع، النقل)	الأمن/حماية البيانات	تقييم معتمد
6.2.4	التعاقد وفق لوائح المشتريات مع شروط الأمن والاستمرارية والخروج	المشتريات	عقد موقع
6.2.5	الاختبار والتشغيل التجريبي وقبول مالك الخدمة	التقنية/مالك الخدمة	تقرير قبول
6.2.6	التسجيل في سجل الأنظمة وإصدار بطاقة نظام حرج عند انطباقه	التقنية	بطاقة النظام

6.3 التطوير الداخلي

الأحكام:

115. يُحفظ الكود المصدري في مستودع مقيد الوصول مع سجل تغييرات (Version Control)، ولا يُخزن الكود على أجهزة شخصية أو وسائط خارجة عن سيطرة الجهة.

116. تُراجع الشيفرة والمكونات والمكتبات والصلاحيات والتكاملات وإدارة الأسرار قبل النشر، وتُحدَّث المكونات المفتوحة المصدر بانتظام.
117. تُفصل بيئات التطوير والاختبار والإنتاج، ولا تُستخدم بيانات حقيقية حساسة في الاختبار إلا بموافقة معتمدة وإخفاء مناسب (تعمية/تركيب بيانات اصطناعية).

6.4 الاختبار والقبول

الأحكام:

118. يُختبر كل نظام أو تغيير جوهري قبل الإطلاق في: الوظائف، والأمن، والأداء، والتوافق، وإجراءات الاسترداد، وقابلية الاستخدام.
119. تُوثق معايير القبول قبل الاختبار، ويوقع مالك الخدمة على تقرير القبول، ولا يُطلق النظام قبل استيفائها أو توثيق قبول استثناء معلل.

6.5 التحديثات وإدارة الثغرات

الأحكام:

120. تُحدَّد أهداف معالجة الثغرات حسب تصنيف الشدة (استرشادي قابل للتخصيص):

شدة الثغرة	الهدف الاسترشادي للمعالجة
حرجة (تصيب أنظمة مكشوفة للإنترنت أو بيانات حساسة)	≤ {{معالجة الثغرات الحرجة}} يومًا (لا تتجاوز 14 يومًا)
عالية	≤ {{معالجة الثغرات العالية}} يومًا (لا تتجاوز 30 يومًا)
متوسطة	≤ {{معالجة الثغرات المتوسطة}} يومًا (لا تتجاوز 90 يومًا)
منخفضة	في دورة التحديث الدورية

121. تُجرى فحوص دورية (مسح ضعف آلي شهريًا استرشاديًا، ومراجعة يدوية عند التغييرات الجوهرية)، واختبار اختراق سنوي استئناسي للأنظمة الحرجة بواسطة جهة متخصصة.
122. تُطبق التحديثات بعد اختبار في بيئة مشابهة وخلال نافذة صيانة معلنة وخطة رجوع (انظر الباب الثامن).

6.6 الأنظمة الحرجة

الأحكام:

123. تُصنف الأنظمة الحرجة بالمعايير التالية: أثر التوقف على المستفيدين أو الأموال أو الامتثال، وصعوبة التعويض اليدوي، وطبيعة البيانات (مالية/شخصية حساسة).
124. لكل نظام حرج بطاقة نظام حرج معتمدة (النموذج 4) تشمل: مالك النظام، البيانات، المورد، مستوى الخدمة، RTO/RPO، النسخ، والبدائل.
125. تُراجع بطاقات الأنظمة الحرجة نصف سنويًا، وتنعقد عليها ضوابط أشد: موافقات إضافية، واختبارات استعادة أكثر تواترًا، وخطط بديلة موثقة.
126. إذا صنفت الهيئة الوطنية للأمن السيبراني أنظمة الجهة ضمن الأنظمة الحرجة، تُطبق عليها ضوابط الأمن السيبراني للأنظمة الحرجة (CSCC) وما يستجد منها.

6.7 إيقاف الأنظمة والأرشفة

الأحكام:

127. لا يُوقف نظام إلا بخطة موثقة تشمل: إخطار المستخدمين قبل {{مدة إشعار إيقاف نظام}} يومًا، وتصدير البيانات بصيغ قابلة للاستخدام والقراءة، وأرشفة السجلات وفق جدول مدد الاحتفاظ (الباب الحادي عشر)، وإلغاء الاشتراكات والصلاحيات والحسابات المرتبطة.
128. تُوثق عملية الإيقاف والأرشفة في تقرير إغلاق يعتمد من مالك الخدمة والتقنية.

الباب السابع: النسخ الاحتياطي والاستمرارية والتعافي

7.1 سياسة النسخ الاحتياطي

الأحكام:

129. تُنسخ جميع البيانات والأنظمة والتكوينات الحرجة وفق جدول معتمد يحدد: نطاق النسخ، وتيرته، والوسيط، وموقع النسخة، ومدة الاحتفاظ، ومسؤول كل مهمة.

130. تُحفظ نسخة على الأقل في موقع منفصل (خارج الموقع الرئيسي أو سحابة مستقلة)، وتُشفر النسخ أثناء النقل والتخزين، وتُقيّد صلاحيات الوصول إليها.

131. تُراجع مهام النسخ أسبوعيًا وتُعاد المحاولات الفاشلة وتوثق النتائج؛ ولا يُعد ظهور مهمة النسخ «ناجحة» دليلًا على سلامة البيانات ما لم تُختبر الاستعادة.

7.2 أهداف الاستعادة RTO/RPO

الأحكام:

132. تُحدد أهداف RTO وRPO لكل خدمة حرجة بناءً على أثر التوقف، وتعتمد من مالك الخدمة، وتُراجع سنويًا وبعد كل حادث جوهري.

133. يُراعى في التصنيف التالي (استرشادي قابل للتخصيص في جداول حقول التخصيص):

الفئة	وصف أثر التوقف	RTO استرشادي	RPO استرشادي
1 (حرجة جدًا)	توقف مالي أو نظامي أو خدمة للمستفيدين مباشرة	≤ 4 ساعات	≤ 1 ساعة
2 (حرجة)	تعطيل عمل رئيسي مع بدائل يدوية محدودة	≤ 24 ساعة	≤ 4 ساعات
3 (مهمة)	إزعاج تشغيلي قابل للتعويض	≤ 72 ساعة	≤ 24 ساعة
4 (عادية)	خدمات داعمة	≤ أسبوع	≤ أسبوع

7.3 اختبار الاستعادة

الأحكام:

134. تُختبر القدرة الفعلية على الاستعادة وفق الجدول التالي (استرشادي): استعادة عينات بيانات أسبوعيًا، واستعادة خدمة أساسية شهريًا، وتمرين تعافٍ شامل نصف سنويًا.

135. يقيس كل اختبار: الزمن الفعلي للاستعادة مقابل RTO، واكتمال البيانات مقابل RPO، وسلامة النتائج، ويُوثق في محضر اختبار استعادة (النموذج 6) مع معالجة الفجوات.

7.4 استمرارية الأعمال التقنية

الأحكام:

136. يُجرى تحليل أثر أعمال مبسط (BIA) سنويًا لتحديد: الوظائف الحرجة، ومدد التحمل المقبلة للتوقف، والموارد البديلة المطلوبة.

137. تُعد خطة استمرارية تقنية لكل خدمة حرجة تشمل: بدائل التشغيل اليدوية المؤقتة، وترتيبات العمل عن بُعد، وقنوات التواصل مع الموظفين والمستفيدين، وأدوار الفريق عند الطوارئ.

138. تُعلن قناة الخدمة البديلة للمستخدمين عند التعطل وتُحدَّث بانتظام حتى الاستعادة.

7.5 خطة التعافي من الكوارث

الأحكام:

139. تُعد خطة تعافٍ من كوارث معتمدة تغطي السيناريوهات الأكثر ترجيحًا: تعطل الموقع الرئيسي، وفقدان مزود الخدمة السحابية، وهجمات الفدية، وضياع بيانات جوهري.
140. تحدد الخطة: تسلسل الاستعادة حسب أولوية الخدمات، ومواقع التشغيل البديلة (سحابية أو بديلة)، وأدوار فريق التعافي، وإجراءات التواصل، ومعايير فك التعافي.
141. تُختبر الخطة نصف سنويًا (تمرين محاكاة على الأقل، وتمارين عملية دورية بحسب القدرة)، وتُحدَّث بعد كل اختبار أو حادث.

7.6 النسخ والتعافي في البيئات السحابية

الأحكام:

142. يُحدد في العقد مع المزود السحابي نموذج النسخ الاحتياطي والاستعادة ومواقعها، وتُختبر الاستعادة من السحابة فعليًا، ولا يُكتفى بواجهة المزود.
143. لا تُترك الأنظمة الحرجة مع مزود سحابي واحد دون خطة بديلة أو نسخة قابلة للنقل (انظر الباب الثالث عشر).

الباب الثامن: إدارة التغيير التقني والإصدارات

8.1 تصنيف التغييرات

الأحكام:

التصنيف	الوصف	أمثلة	مسار الاعتماد
قياسي (Standard)	تغيير روتيني منخفض الخطرة مجرَّب سابقًا	إضافة مستخدم، تحديث محطة عمل	موافقة مسبقة موثقة مرة واحدة، وتنفيذ موثق
عادي (Normal)	تغيير متوسط الأثر	تحديث إصدار نظام، تعديل تقرير	لجنة التغيير ثم التنفيذ
جوهري (Major)	تغيير عالٍ الأثر أو يمس نظامًا حرجًا أو بيانات حساسة	تغيير نظام مالي، نقل استضافة، تكامل جديد	لجنة التغيير + موافقة الإدارة التنفيذية/مالك الخدمة
طارئ (Emergency)	تغيير لاحتواء حادث أو خطر وشيك	سد ثغرة مستغلة، استعادة خدمة متعطلة	موافقة طارئة مسبقة مع توثيق لاحق خلال {{مدة توثيق موافقة الطوارئ}} يوم عمل

8.2 دورة حياة طلب التغيير

الأحكام:

144. يُقدم طلب التغيير (النموذج 1) ويشتمل كحد أدنى على: الوصف والمبرر، والنطاق، والمالك، وتقييم الأثر والمخاطر، وتقييم الأمن والخصوصية عند الحاجة، وخطة الاختبار ومعايير القبول، وخطة التنفيذ والوقت والإشعار، وخطة الرجوع.
145. تُراجع الطلبات بحسب تصنيفها (8.1)، وتُعتمد قبل التنفيذ، ولا يُنفذ تغيير دون طلب موثق إلا في حالات الطوارئ المعلنة.
146. بعد التنفيذ: يُعلن الانتهاء، ويوقع مالك الخدمة على القبول، وتُجرى مراجعة ما بعد التنفيذ للتغييرات الجوهرية وتُوثق الدروس.

الإجراءات التشغيلية:

الخطوة	الوصف	المسؤول	السجل/الوثيقة

الخطوة	الوصف	المسؤول	السجل/الوثيقة
8.2.1	تقديم طلب التغيير واستيفاء الحقول	طالب التغيير	نموذج طلب تغيير
8.2.2	تقييم أولي وتصنيف	التقنية	قرار تصنيف
8.2.3	تقييم أمن وخصوصية عند انطباقه	الأمن/حماية البيانات	تقييم معتمد
8.2.4	عرض على لجنة التغيير/الجهة المخولة واعتماد	CAB	محضر اعتماد
8.2.5	التنفيذ والاختبار وتوثيق النتائج	التنفيذ	سجل تنفيذ
8.2.6	قبول مالك الخدمة ومراجعة ما بعد التنفيذ	مالك الخدمة/التقنية	تقرير إغلاق

8.3 لجنة مراجعة التغييرات (CAB)

الأحكام:

147. تتكون اللجنة من: منسق التقنية (رئيسًا)، مالك الخدمة المتأثرة، الأمن/حماية البيانات عند الحاجة، وممثل مالي عند التغييرات المؤثرة على العقود أو الموازنة.

148. تنعقد كل {{دورية اجتماعات CAB}} أو عند الطلب، ويصدر قرارها موثقًا، ويجوز الاعتماد الإلكتروني غير المتزامن للطلبات العادية.

8.4 الإصدارات والنشر

الأحكام:

149. تُوثق الإصدارات في سجل إصدارات لكل نظام (رقم الإصدار، التاريخ، التغييرات، المعتمد).

150. تُنشر التغييرات في نوافذ معلنة خارج أوقات الذروة، مع إشعار المستخدمين المتأثرين قبل {{مدة إشعار التغيير}} يومًا، وتُجرى اختبارات ما بعد النشر.

8.5 التراجع عن التغيير

الأحكام:

151. يجب أن تتضمن خطة كل تغيير جوهري خطة رجوع قابلة للتنفيذ ومختبرة نظريًا، تحدد: مسؤول الرجوع، والخطوات، والوقت المتوقع، ومعايير تفعيل الرجوع.

152. يُفعَّل الرجوع فور تجاوز أحد معايير الفشل المعلنة، ويُوثق في تقرير الحادث/التغيير وتُدرس الأسباب.

الباب التاسع: الدعم الفني ومستويات الخدمة

9.1 قنوات الدعم ونقطة الاتصال

الأحكام:

153. تقدم الجهة قناة دعم موحدة معلنة: {{قنوات الدعم المعتمدة}} (بريد/نموذج إلكتروني/هاتف/قناة مراسلة)، وتُحدد ساعات التغطية {{ساعات تغطية الدعم}}.

154. جميع الطلبات تُسجل في نظام تتبع واحد (تذكرة) برقم مرجعي، ولا يُعالج طلب خارج النظام إلا في الطوارئ مع تسجيله لاحقًا.

9.2 تصنيف الطلبات

الأحكام:

فئة الطلب	الوصف	مثال	المسار
طلب خدمة	طلب جديد معتاد بإجراء معروف	حساب، جهاز، صلاحية، برنامج	نموذج واعتماد وتنفيذ وموافقة المستفيد
حادث	توقف أو خلل يؤثر على خدمة	تعطل نظام، انقطاع شبكة	تسجيل وتصنيف وتصعيد واستعادة وتوثيق الحل
حادث أمني	تصيد أو فقدان أو وصول غير مصرح أو برمجية خبيثة	اختراق بريد، فقدان جهاز	إبلاغ فوري واحتواء وتنسيق أمني (الباب العاشر)
تغيير	ترقية أو تعديل أو تكامل	تحديث إصدار، تعديل إعداد	تقييم واعتماد واختبار وخطة رجوع (الباب الثامن)
مشكلة متكررة	أعطال مترابطة بسبب جذري	تكرار تعطل النظام نفسه	تحليل سبب جذري وخطة إزالة
استفسار	سؤال أو توعية	كيف أستخدم النظام؟	إجابة وتوثيق في قاعدة المعرفة

9.3 مستويات الخدمة (SLA)

الأحكام:

155. تُصنف الطلبات حسب أثر الخدمة وعدد المتأثرين والحساسية والبدائل المتاحة، وتعتمد مستهدفات الاستجابة والاستعادة التالية (استرشادية):

الأولوية	الوصف	مثال	استجابة استرشادية	استعادة/حل استرشادي
P1 حرجة	توقف خدمة حرجة أو حادث أمني نشط	تعطل النظام المالي، اختراق نشط	≤ 30 دقيقة	≤ 4 ساعات (عمل على مدار الساعة)
P2 عالية	أثر جوهري على عمل رئيسي مع بدائل جزئية	تعطل وحدة، فقدان اتصال فرع	≤ 4 ساعات	≤ يوم عمل
P3 متوسطة	أثر محدود يمكن التعايش معه	خلل في تقرير، مشكلة جهاز فردي	≤ يوم عمل	≤ 3 أيام عمل
P4 منخفضة	طلبات واستفسارات عادية	إضافة برنامج، استفسار	≤ يومان	≤ 5 أيام عمل

156. تُعرض المستهدفات المعتمدة على المستخدمين وتُراجع سنويًا بعد قياس الأداء الفعلي.

157. الاتفاقيات الداعمة: تُوثق الاتفاقيات التشغيلية الداخلية (OLA) بين التقنية والوحدات، وتُراجع العقود مع الموردين (UC) للتأكد من أن وعود الموردين تمكّن من الوفاء بمستويات الخدمة المعلنة.

158. يُقاس الأداء من زاويتين: تحقق SLA الفني، وتجربة المستفيد الفعلية (XLA: زمن حل من منظور المستخدم، ورضاه)، ولا يُكتفى بأخضر الأرقام الفنية مع استياء المستخدمين.

9.4 التصعيد

الأحكام:

159. تصعيد داخلي: عند اقتراب انتهاء مستهدف الاستجابة دون حل، يُصعَّد الطلب تلقائيًا للمستوى الأعلى.
160. تصعيد للمورد: للحوادث المتعلقة بأنظمة موردين يُفعَّل التصعيد وفق العقد مع تسجيل مرجع المورد.
161. تصعيد إداري: للحوادث الجوهرية أو الحوادث الأمنية يُبلَّغ {{جهة التصعيد الإداري}} فورًا.

9.5 إدارة المشكلات والمنع

الأحكام:

162. تُحلل الأعطال المتكررة لتحديد السبب الجذري، وتُنشأ سجل مشكلات يتضمن: الوصف، والتحليل، وخطة الإزالة، والمالك، وتاريخ الإغلاق.
163. تُوثق الحلول المعتمدة في قاعدة معرفة داخلية يستطيع المستخدمون الاستفادة منها.

9.6 إغلاق الطلبات ورضا المستفيدين

الأحكام:

164. لا تُغلق التذكرة قبل تأكيد المستفيد من الحل أو توثيق سبب الإغلاق، وتُرسل استبيان رضا بعد الإغلاق، ويُحلل الرضا شهريًا مع قراءة نوعية للتعليقات.

الباب العاشر: الحوادث التقنية والاستجابة

10.1 تعريف الحادث وتصنيفه

الأحكام:

165. الحادث التقني كل حدث غير مخطط يقلل جودة أو توافر خدمة أو يمس أمن الأصول أو البيانات، ويشمل: الأعطال التشغيلية، وفقدان البيانات، والحوادث الأمنية (تصيد، برمجية خبيثة، وصول غير مصرح، اختراق، فدية)، وفقدان الأجهزة.
166. تُصنف الحوادث بشدة (حرجة/عالية/متوسطة/منخفضة) بحسب: أثرها على المستفيدين والأموال والامتثال، ونطاقها، وإمكان الاحتواء.

10.2 الإبلاغ وسلوك المستخدم

الأحكام:

167. يلزم كل من يعلم بحادث بالإبلاغ الفوري عبر {{قناة الإبلاغ عن الحوادث}}، وتُعلن القناة للجميع ويُدرَّبون عليها.
168. يُمنع على المستخدم عند الاشتباه بحادث: حذف الأدلة أو إعادة تشغيل/تهيئة الجهاز المتأثر، أو التواصل مع الجاني، أو نشر خبر الحادث خارج القنوات المعتمدة، أو محاولة «إصلاح» المشكلة بنفسه.
169. يحصل المبلغ على حماية من أي إجراء تعسفي بسبب بلاغ حسن النية وفق سياسات الجهة.

10.3 الاستجابة والاحتواء

الأحكام:

170. تُحتوى الحوادث وفق خطة مسبقة تشمل: عزل الجهاز من الشبكة، أو تعطيل الحساب المتأثر، أو تعليق خدمة مؤقتًا، مع حفظ السجلات والصور الجنائية الرقمية والتواريخ والأدلة.
171. يُشكل مسار الاستجابة: منسق التقنية (مدير الحادث)، والأمن/حماية البيانات، ومالك الخدمة، والإدارة التنفيذية عند الجوهرية، والشؤون القانونية والإعلام عند الحاجة.
172. تُفعَّل خطط العمل البديلة والاستعادة وفق RTO/RPO (الباب السابع)، وتوضح للمستخدمين قناة الخدمة البديلة والتحديثات المعتمدة.
173. تُشرك الجهات الخارجية (الجهات الأمنية، سدايا، الهيئة الوطنية للأمن السيبراني) عند وجود أساس نظامي أو خطر وطني أو اشتراط تعاقدي.

10.4 الإخطار النظامي والتزامات الإفصاح

الأحكام:

174. حوادث البيانات الشخصية: إذا أدى الحادث أو تسبب من المحتمل أن يؤدي إلى اختراق البيانات الشخصية أو حدوث ضرر بها أو بخصوصيتها أو بمصالح صاحب البيانات، وجب إخطار سدايا خلال (72) ساعة كحد أقصى من العلم بالحادث وفق اللائحة التنفيذية لنظام حماية البيانات الشخصية والدليل الإجرائي لحوادث الاختراق، وقد يتبع الإخطار الأولي إخطار كامل عند الحاجة، ويجب إخطار صاحب البيانات دون إبطاء وفق الأحكام النظامية عند اللزوم لحمايته.

175. الجرائم الإلكترونية: تُبلَّغ الجهات المختصة وفق نظام مكافحة الجرائم المعلوماتية عند اشتباه جريمة معلوماتية، وتتعاون الجهة في التحريات.

176. المستفيدون والمتعاملون: تقرر الإدارة التنفيذية نطاق إفصاح خارجي للمتعاملين بناء على توصية مسؤول حماية البيانات والشؤون القانونية، وتُوثق قرارات الإفصاح وأسبابها.

177. التواصل الداخلي: لا يصدر أي تصريح عن الحوادث الجوهرية إلا من {{المتحدث الرسمي/الجهة المخولة}}، ويُمنع تداول تفاصيل الحوادث خارج نطاق العمل.

10.5 التعافي والدروس المستفادة

الأحكام:

178. بعد الاحتواء يُجرى تحليل السبب الجذري (RCA)، ويُختبر الإصلاح، وتُحدَّث المخاطر والنسخ والتدريب والعقود بناءً عليه، ويُعتمد إغلاق الحادث من مالك الخدمة والأمن.

179. يُجرى مراجعة ما بعد الحادث خلال {{مدة مراجعة ما بعد الحادث}} يومًا للحوادث الحرجة، ويُرفع تقريره إلى الإدارة التنفيذية (ولمجلس الإدارة عند الجوهرية).

10.6 سجل الحوادث

الأحكام:

180. يُنشأ سجل حوادث يحوي لكل حادث: التصنيف والأزمنة والأطراف والإجراءات والأدلة والإخطارات والإغلاق، ويُحفظ وفق مدد الاحتفاظ (الباب الحادي عشر).

181. يُستخدم قالب الهيئة الوطنية للأمن السيبراني لسياسة إدارة الحوادث مرجعًا في هيكلة السجل والإجراءات.

الباب الحادي عشر: الأرشفة الإلكترونية والسجلات الرقمية

11.1 مبدأ الموثوقية

الأحكام:

182. تُنشأ السجلات الرقمية في نظام قابل للبحث يحفظ سلامة التسلسل والتاريخ والهوية والتعديل، ويحدد الصلاحيات ويوثق الإجراءات.

183. يجب أن تكون السجلات الإلكترونية قابلة للإثبات عند الحاجة القضائية: بسلسلة حيازة موثقة ومنع العبث، مع مراعاة نظام الأدلة السعودي في المعاملة الإثباتية للأدلة الإلكترونية.

11.2 جدول مدد الاحتفاظ

الأحكام:

184. تكون المدد الواردة أدناه حدًّا داخليًا أدنى ما لم يوجد في نظام أو عقد مدة أطول:

185. لا تُتلف السجلات المتعلقة بتحقيق أو نزاع أو طلب جهة مختصة حتى انتهاء الغرض واعتماد الإتلاف من الجهة المختصة.

السجل أو الدليل	المالك	الحد الأدنى للمحتوى	مدة الحفظ
سجل الأصول والتراخيص	التقنية	المالك والموقع والإصدار والتكلفة والانتهاء والحالة	عمر الأصل + سنتان
طلبات الحسابات والصلاحيات	التقنية/الموارد البشرية	الطلب والدور والاعتماد والمدة والمراجعة والإلغاء	انتهاء الحساب + خمس سنوات

السجل أو الدليل	المالك	الحد الأدنى للمحتوى	مدة الحفظ
سجلات التغيير والإطلاق	التقنية/مالك الخدمة	النطاق والاختبار والموافقة والرجوع والنتيجة	خمس سنوات
النسخ والاستعادة	التقنية	النطاق والنتيجة والفشل والاختبار والزمن والمعالجة	سنتان أو أطول حسب الخدمة
الثغرات والتحديثات	التقنية/الأمن	الفحص والشدة والمالك والإصلاح والتحقق	خمس سنوات
تذاكر الدعم	التقنية	التصنيف والأزمنة والإجراء والإغلاق	خمس سنوات
الحوادث والاستجابة	التقنية/الأمن	التصنيف والأزمنة والأطراف والإجراءات والإخطارات	خمس سنوات أو أطول
موافقات ومحاضر اختبار الاستمرارية	التقنية	السيناريو والأهداف والنتائج والفجوات	خمس سنوات
عقود الموردين والمراجعة	المشتريات/التقنية	الخدمة والأمن والنسخ والتقييم والإنهاء	انتهاء العقد + عشر سنوات
سجل أدوات الذكاء الاصطناعي وتقييماتها	التقنية/حماية البيانات	الأداة والغرض والبيانات والتقييم والقرار	خمس سنوات
موافقات البيانات الشخصية وسجلاتها	حماية البيانات	الأساس النظامي والموافقة وسجل المعالجة	مدة المعالجة + {{مدة إضافية لسجلات الموافقات}} سنوات
السجلات الضريبية وفواتير القيمة المضافة	المالية	الفواتير والمستندات الداعمة وأدلة الإقرار	عشر سنوات، وتُحفظ داخل المملكة
السجلات المالية والمحاسبية	المالية	القيود والمستندات المؤيدة	وفق اللوائح المالية والضريبية (لا تقل عن {{مدة حفظ السجلات المالية}} سنوات)

11.3 الأرشفة النظامية والإتلاف

الأحكام:

186. تُراعى أحكام نظام المعاملات الإلكترونية ولائحته: أن من يوجب عليه قانونًا حفظ سجلات إلكترونية يؤدي عمليتي الأرشفة والنسخ الاحتياطي دوريًا بما يكفل حفظ الحقوق، وأن السجل الإلكتروني يجب أن يكون مكتملًا وقابلًا للاسترجاع بصورته الأصلية.

187. يُجرى الإتلاف بموافقة معتمدة ومحضر يحدد: ما أُتلف، والأساس النظامي، والطريقة، والشهود؛ ويُمنع الإتلاف الانتقائي الموجه لإخفاء أثر.

11.4 المتطلبات الضريبية والمالية

الأحكام:

188. تُحفظ السجلات الضريبية والفواتير الإلكترونية داخل المملكة مدة عشر سنوات وفق ضوابط الهيئة العامة للزكاة والضريبة والجمارك، وتتوافق أنظمة الفوترة مع متطلبات المرحلتين عند انطباقهما على أنشطة الجهة.

189. تُراجع الأنظمة المحاسبية دوريًا من حيث جاهزية البيانات للفحص الضريبي والزكوي.

11.5 بريد المراسلات والتوثيق

الأحكام:

190. تُرشف المراسلات الرسمية والبريد الإلكتروني ذو الصلة النظامية والتعاقدية وفق جدول الاحتفاظ، وتحدد سياسة حفظ البريد: مدة بقاء الرسائل في الصندوق الحي ({{مدة بقاء البريد في الصندوق الحي}})، وآلية الأرشفة والاسترجاع.

191. المراسلات على المنصات الرسمية ({{المنصات الرسمية المعتمدة}}) جزء من سجلات الجهة وتُدار بذات الضوابط.

الباب الثاني عشر: الذكاء الاصطناعي المسؤول

12.1 المبادئ الحاكمة

الأحكام:

192. يخضع استخدام الذكاء الاصطناعي في الجهة للمبادئ الأخلاقية السبعة الصادرة عن سدايا، وتُترجم عمليًا كما يلي:

المبدأ (سدايا)	تطبيقه العملي في الجهة
العدالة والإنصاف	مراجعة المخرجات لاكتشاف التحيز ضد فئات المستفيدين (الجنس، الإعاقة، المنطقة) قبل الاعتماد
الخصوصية	عدم إدخال بيانات شخصية في أدوات غير معتمدة، وضبط الاحتفاظ والموافقات
الإنسانية	بقاء القرار النهائي للإنسان في المسائل الإنسانية والاجتماعية
المنفعة الاجتماعية والبيئية	توجيه الاستخدام نحو تحسين خدمات المستفيدين وكفاءة الموارد
الموثوقية والأمان	تقييم الأداة قبل الاعتماد ومراقبة جودة مخرجاتها باستمرار
الشفافية وقابلية التفسير	إعلام المستفيدين عندما تؤثر عليهم مخرجات ذكاء اصطناعي وتمكينهم من السؤال والاعتراض
المساءلة والمسؤولية	تسمية مسؤول بشري معلن عن كل استخدام مؤثر

12.2 حوكمة اعتماد أدوات الذكاء الاصطناعي

الأحكام:

193. تُصنف استخدامات الذكاء الاصطناعي إلى ثلاث فئات:

- محرمة: إدخال بيانات شخصية أو سرية في أدوات عامة غير معتمدة؛ القرارات الآلية النهائية المؤثرة على أفراد؛ انتحال صوت أو صورة أشخاص دون إذن؛ توليد محتوى مضلل أو مخالف.
- مشروطة: الاستخدام المساند للكتابة والترجمة والتصميم والتحليل — بشرط الأداة المعتمدة والمراجعة البشرية وضوابط البيانات.
- مسموحة: الاستخدامات الإدارية العامة المنخفضة الحساسية (صياغة مسودات داخلية، تلخيص مستندات غير سرية).

194. قبل اعتماد أي أداة ذكاء اصطناعي يُجرى تقييم معتمد يشمل: الجهة المطورة وموقع معالجة البيانات، وآلية الاحتفاظ والتدريب على المدخلات، وشروط الترخيص وحقوق المخرجات، ومخاطر التحيز والدقة، وبدائل محلية أو داخل المملكة عند توفرها (قائمة الفحص 7).

195. يُحظر إنشاء حسابات ظل (Shadow AI) أو تكاملات غير معتمدة مع أدوات خارجية.

12.3 حماية البيانات في أدوات الذكاء الاصطناعي

الأحكام:

196. لا تُدخل بيانات سرية أو شخصية أو قضايا مستفيدين في أدوات ذكاء اصطناعي عامة دون اعتماد الأداة وتقييم المعالجة والمورد والموقع والاحتفاظ — ويبقى نظام حماية البيانات الشخصية حاكمًا لكل معالجة.

197. تُفضل المعالجة داخل المملكة أو لدى مزود ملتزم بضوابط نقل البيانات النظامية، وتُوثق الحالات المستثناة بموافقة معتمدة من مسؤول حماية البيانات.

198. يُراعى حظر الإعلان التسويقي المباشر المبني على معالجة آلية دون موافقة نظامية، وحق الأفراد في عدم الخضوع لقرار آلية خالصة في الحالات التي يقررها النظام.

12.4 مراجعة المخرجات

الأحكام:

199. تُراجع جميع المخرجات المؤثرة بشريًا قبل الاعتماد، وتشمل المراجعة: الدقة والمطابقة للواقع، والتحيز، والخصوصية، وحقوق الملكية الفكرية، والملاءمة للسياق الشرعي والاجتماعي.

200. يُوثق اعتماد المخرجات الحساسة (نشرات، تقارير، قرارات) بتوقيع منشئها البشري الذي تحقق منها.

201. لا تُستخدم مخرجات الذكاء الاصطناعي لاتخاذ قرار مؤثر على فرد (قبول مستفيد، صرف مبلغ، جزاء) دون مراجعة مؤهلة بشرية ومسار اعتراض معلن.

12.5 الملكية الفكرية للمخرجات

الأحكام:

202. يُراعى أن مخرجات الذكاء الاصطناعي قد لا تتمتع بحماية تلقائية بموجب نظام حقوق المؤلف ما لم يتصل بها إسهام إنساني مبدع مؤثر؛ لذا تُوثق الأدوات المستخدمة ونسب الإسهام البشري في المنتجات النهائية (تقارير، مواد توعوية، تصاميم).

203. عند نشر مواد مولدة أو معدلة بالذكاء الاصطناعي خارجيًا (موقع، منشورات، طباعة) تُراجع قانونيًا من حيث: عدم انتهاك حقوق الغير، وشروط ترخيص الأداة للاستخدام التجاري/العام، وإمكان إسناد الحقوق للجهة.

204. تُراعى في أدوات الذكاء الاصطناعي المعتمدة شروط ترخيص المخرجات (من يملكها وحدود الاستخدام)، وتُدرس بدائل تمنح الجهة حقوقًا أوضح عند تكافؤ الجودة.

205. تُحظر ادعاء الملكية الحصرية لمخرجات مولدة آلية دون أساس نظامي واضح في العقود والتراخيص.

12.6 توعية وإقرار المستخدمين

الأحكام:

206. يُدرَّب العاملون والمتطوعون على الاستخدام المسؤول، ويوقعون إقرارًا بالمحظورات: عدم إدخال بيانات شخصية أو سرية في أدوات غير معتمدة، وعدم نسب مخرجات خاطئة، وعدم استخدام الأدوات للانتحال أو التضليل.

الباب الثالث عشر: الخدمات السحابية والموردون التقنيون

13.1 المبادئ

الأحكام:

207. تُقيَّم خيارات الحوسبة السحابية قبل أي استثمار تقني جديد (استئناسًا بسياسة «السحابة أولًا»)، ولا يُختار النموذج (سحابي عام/خاص/هجين أو محلي) إلا بعد تحليل: حساسية البيانات، والكلفة الكلية، والاستمرارية، وقابلية الخروج.

208. يطبق نموذج المسؤولية المشتركة: المزود مسؤول عن أمن «السحابة»، والجهة مسؤولة عمّا في «السحابة» (بياناتها، هوياتها، إعداداتها، صلاحيات وصولها).

209. تفضل الجهة التعاقد مع مزود مسجل لدى هيئة الاتصالات والفضاء والتقنية وفق الإطار التنظيمي لحوسبة السحابة، وتتحقق من حالة التسجيل سنويًا.

13.2 اعتماد المزود السحابي

الأحكام:

210. قبل التعاقد تُوثق دراسة المزود تشمل: التسجيل النظامي والشهادات، ومواقع مراكز البيانات ومناطقها، ومواقع الدعم الفني، والمقاولون من الباطن، ونموذج النسخ والاستعادة، وضوابط الحوادث، وإمكانية التدقيق، والإنهاء وإرجاع البيانات (قائمة الفحص 8).

211. لا تُستضاف البيانات ذات المستوى الأعلى حساسية (وفق التصنيف المعتمد في الإطار التنظيمي للحوسبة السحابية) إلا لدى مزود مستوفٍ لاشتراطات إقامة البيانات داخل المملكة، وتُوثق دراسة التصنيف قبل النقل.

13.3 العقود مع الموردين التقنيين

الأحكام:

212. تتضمن الاتفاقية مع أي مورد تقني جوهري: نطاق الخدمة ومستوياتها (SLA)، ومتطلبات الأمن وحماية البيانات، وإدارة الحوادث وآلية الإبلاغ والتصعيد، وحقوق التدقيق والمراجعة، وإجراءات التغيير الجوهرية، والإشعار المبكر قبل التغييرات المؤثرة، وإرجاع البيانات عند الإنهاء بصيغ قابلة للاستخدام مع شهادة محو، وقابلية النقل وعدم الاحتكار، وسرية المعلومات ومدة بقائها بعد الإنهاء.

213. يُراجع العقد سنويًا مقابل الأداء الفعلي ويُوثق محضر المراجعة.

13.4 البيانات الشخصية عبر الحدود

الأحكام:

214. لا يجوز نقل البيانات الشخصية خارج المملكة أو الإفصاح عنها لجهة خارجها إلا وفق أحكام المادة (29) من نظام حماية البيانات الشخصية ولائحة نقل البيانات الشخصية خارج المملكة (المحدَّثة 2024/09/01م)، ومن ذلك: الالتزام بالبنود التعاقدية المعيارية (SCCs) عند الاعتماد عليها، وتقييم المخاطر (وفق دليل سدايا)، والحد الأدنى من البيانات المنتقلة، وتوثيق الأساس النظامي للنقل في سجل المعالجة.

215. تُعرض حالات النقل على مسؤول حماية البيانات للموافقة قبل التعاقد، وتُراجع دوريًا استمرار الحاجة للنقل.

13.5 مراجعة الموردين وتقييمهم

الأحكام:

216. يُقيَّم أداء الموردين التقنيين الجوهريين سنويًا: تحقق مستويات الخدمة، واستجابة الحوادث، وملاحظات الأمن، وقيمة التكلفة، ويُوثق التقييم في محضر يعتمد من الجهة المختصة.

217. يُنهى التعاقد مع مورد متكرر الإخلال بعد استنفاد خطوات المعالجة وفق العقد والأنظمة.

13.6 الخروج وقابلية التنقل

الأحكام:

218. تُختبر إمكانية الخروج من كل مورد جوهري (تصدير البيانات، وإعادة الإنشاء في بديل، وتعقيدات التكامل)، ولا تُترك الأنظمة الحرجة دون خطة بديلة موثقة.

219. عند الإنهاء: تُصدَّر البيانات كاملة بصيغ قابلة للاستخدام، وتُستلم شهادة محو بيانات الجهة من أنظمة المورد بعد التحقق، وتُلغى الحسابات والصلاحيات والمفاتيح المشتركة.

الباب الرابع عشر: الامتثال والمخالفات والاستثناءات والتصعيد

14.1 الامتثال

الأحكام:

220. تلتزم الجهة بالأنظمة واللوائح والضوابط الوطنية النافذة الواردة في المراجع، وتُراجع الالتزامات دوريًا وتُدرج في تقرير امتثال سنوي يعرض على الإدارة التنفيذية ومجلس الإدارة.

221. لا تُعد المعايير الدولية الاستئناسية (ISO/ITIL وغيرها) التزامًا على الجهة إلا إذا تبنتها صراحة في وثيقة معتمدة أو أوجبها عقد أو مرجع رسمي.

14.2 الاستثناءات

الأحكام:

222. كل استثناء تشغيلي يكون: مكتوبًا، ومسببًا، ومحدد المدة، ومعتمدًا من صاحب الصلاحية، وقابلًا للتتبع، ومسجلًا في سجل الاستثناءات، ويُغلق عند انتهاء مدته أو إلغاء الحاجة.

223. لا يُقبل أي استثناء يسمح بمخالفة نظام سارٍ، أو يقلص حقًا لعامل أو متطوع أو مستفيد أو متبرع، أو يلغي موافقة نظامية، أو يعرض بيانات شخصية لخطر غير مبرر.

14.3 المخالفات

الأحكام:

224. تُسجل المخالفة في سجل موحد يتضمن الوصف والأثر والمسؤول والإجراء الفوري والموعد المستهدف للإغلاق، مع حفظ الأدلة دون إخفاء أو تعديل بأثر رجعي.

225. تُعالج مخالفات الموظفين وفق نظام العمل ولائحة المخالفات والجزاءات بعد التحقيق وسماع الأقوال وضمان التظلم، وتُعالج مخالفات المتطوعين والمقاولين والموردين وفق العقود واللوائح والأنظمة ذات الصلة.

226. من أبرز المخالفات التقنية الجسيمة: استخدام برمجيات مقرصنة، مشاركة كلمات المرور، إخفاء حادث أو التلاعب بأدلته، إدخال بيانات سرية في أدوات غير معتمدة، تجاوز الصلاحيات، تعطيل أدوات الحماية.

14.4 التصعيد

الأحكام:

227. يُصعَّد فورًا إلى المستوى المختص: البلاغ ذو الخطر النظامي أو المالي، أو المتعلق بالسلامة أو حماية الطفل أو البالغين الضعفاء، أو بحوادث البيانات الشخصية الجوهرية، أو بمؤشرات جريمة إلكترونية.

228. تُستخدم قنوات الجهات الرسمية عندما يوجب النظام ذلك أو عند وجود خطر وشيك (سدايا، الجهات الأمنية، الهيئة الوطنية للأمن السيبراني، المركز الوطني).

الباب الخامس عشر: المراجعة والتحديث والاعتماد

15.1 مراجعات السياسة

الأحكام:

229. يراجع مالك الوثيقة السياسة سنويًا على الأقل، وقبل ذلك عند: صدور أو تعديل مرجع نظامي، أو تغير شكل الجهة القانوني أو نشاطها، أو وقوع حادث جوهري، أو ظهور نتيجة تدقيق أو تقييم مخاطر يستلزم التعديل.

230. يوثق سجل المراجعة ما تم فحصه وما تغير وأسباب الاعتماد أو الإبقاء.

15.2 التوزيع وإدارة النسخ

الأحكام:

231. تُسلَّم النسخة المعتمدة إلى أصحاب العلاقة بطريقة قابلة للإثبات، وتُسحب النسخ الملغاة من نقاط الاستخدام مع الاحتفاظ بنسخة أرشيفية.

232. لا يعمل بأي مسودة أو نسخة غير معتمدة، ويُعرض التعديل الجوهري على الجهة نفسها التي اعتمدت الوثيقة أو على جهة أعلى إذا تغير الاختصاص.

15.3 الأحكام الانتقالية

الأحكام:

233. تعمل الجهة بجدول انتقالي {{مدة الأحكام الانتقالية}} يومًا من تاريخ الاعتماد لاستيفاء: إكمال سجل الأصول، واعتماد سياسة كلمات المرور وتفعيل MFA، وجرد الأنظمة الحرجة وتعيين أهداف الاستعادة، وإنشاء سجل الاستثناءات.

234. يُعد تقرير استكمال الانتقالي إلى الإدارة التنفيذية في نهاية المدة.

15.4 جدول الاعتماد

عنصر الاعتماد	البيان
إعداد ومراجعة المحتوى	.....
المراجعة النظامية/القانونية	.....
المراجعة الأمنية	.....
قرار الاعتماد ورقمه وتاريخه	.....
تاريخ النفاذ وموعد المراجعة التالية	.....
اسم المفوض بالتوقيع وصفته وتوقيعه	.....
موافقة الجهة المشرفة إن لزم	.....

حقول التخصيص الموسعة

جميع الجداول التالية إلزامية التعبئة قبل الاعتماد (PPW-3). القيم بين قوسين معكوسين {{}} تُستبدل ببيانات الجهة المعتمدة.

الجدول (16-1): بيانات الجهة التقنية العامة

الحقل	الوصف	القيمة المعبأة
اسم الجهة	الاسم النظامي المعتمد	{{اسم الجهة}}
الشكل القانوني	جمعية أهلية/مؤسسة أهلية/تعاونية	{{الشكل القانوني}}
المقر الرئيسي	المدينة والحي	{{المدينة – الحي}}
الفروع والمكاتب	عددها ومواقعها	{{الفروع والمكاتب}}
حجم العمل	موظفون/متطوعون/مستفيدون سنويًا	{{حجم العمل}}
المنصات الرقمية الرسمية	الموقع، الحسابات، المنصات الحكومية المرتبطة	{{المنصات}}
مستوى الامتثال التقني المستهدف	أساسي/متقدم (تصنيف دفة)	{{مستوى الامتثال}}
ميزانية تقنية المعلومات السنوية	بند تشغيلي + بند رأسمالي	{{الميزانية}}
اعتمادية خارجية	هل تتلقى تمويلًا مانحًا يفرض اشتراطات تقنية	{{اشتراطات التمويل}}

الجدول (16-2): الحوكمة والاستراتيجية

الحقل	الوصف	القيمة المعبأة
مسؤول تقنية المعلومات/المنسق	الاسم والصفة والتكليف	{{مسؤول التقنية}}
جهة رئاسة اللجنة التوجيهية		{{جهة الرئاسة}}

الحقل	الوصف	القيمة المعبأة
دورية اجتماعات اللجنة التوجيهية		{{الدورية}}
دورية اجتماعات لجنة التغيير (CAB)		{{دورية CAB}}
دورية مراجعة الصلاحيات	لا تتجاوز ربع سنة	{{دورية المراجعة}}
نسبة انحراف البند المالية المقبولة	قبل التصعيد	{{نسبة الانحراف}}%
حد الصلاحية المالية لتعيينات التقنية	للقرار الواحد	{{الحد}} ريال
دورة تقييم الأداء التقني الشاملة		{{دورة التقييم}}

الجدول (16-3): الأصول والتراخيص

الحقل	الوصف	القيمة المعبأة
عدد أجهزة الجهة (تقديري)	حواسيب ومحمولات وطابعات	{{عدد الأجهزة}}
دورة استبدال الحواسيب المكتبية	سنوات	{{دورة المكتبية}}
دورة استبدال الأجهزة المحمولة	سنوات	{{دورة المحمولة}}
مسؤول الجرد والأرشيف		{{مسؤول الجرد}}
دورية الجرد الشامل		{{دورية الجرد}}
أدوات إدارة الأجهزة (MDM) المعتمدة إن وجدت		{{أدوات MDM}}
مدة التنبيه قبل انتهاء الترخيص/النطاق	أيام	{{مدة التنبيه}}

الجدول (16-4): الهوية والأجهزة والعمل عن بُعد

الحقل	الوصف	القيمة المعبأة
سياسة MFA المعتمدة	نطاق التفعيل الإلزامي	{{نطاق MFA}}
سياسة كلمات المرور	الطول والتعقيد ودورة التغيير	{{سياسة كلمات المرور}}
مدة قفل الشاشة	دقائق	{{مدة القفل}}
نموذج حل BYOD المعتمد	حاوية عمل/تطبيق إدارة/غيره	{{حل BYOD}}
قناة الوصول البعيد المعتمدة	VPN/بوابة/خدمة سحابية	{{قناة الوصول}}
منهجية العمل عن بُعد	نسبة/أيام/حسب الاتفاق	{{منهجية العمل عن بعد}}

الجدول (16-5): البريد والشبكات

الحقل	الوصف	القيمة المعبأة

الحقل	الوصف	القيمة المعبأة
نطاق البريد المؤسسي		{{النطاق}}
مزود البريد والاستضافة		{{المزود}}
النطاقات المسجلة وتواريخ انتهائها		{{النطاقات}}
مسؤول سجل النطاقات والشهادات		{{المسؤول}}
قناة الإبلاغ عن التصيد		{{قناة الإبلاغ}}
بنية الشبكات المعتمدة	شرح موجز للتقسيم	{{بنية الشبكات}}

الجدول (16-6): الأنظمة والاستمرارية والتعافي

النظام/الخدمة	المالك	فئة الحرجية (1–4)	RTO معتمد	RPO معتمد	موقع النسخ	مزود/مستضيف	تاريخ آخر اختبار استعادة
{{النظام 1}}	{{المالك}}	{{الفئة}}	{{RTO}}	{{RPO}}	{{الموقع}}	{{المزود}}	{{التاريخ}}
{{النظام 2}}	{{المالك}}	{{الفئة}}	{{RTO}}	{{RPO}}	{{الموقع}}	{{المزود}}	{{التاريخ}}
{{النظام 3}}	{{المالك}}	{{الفئة}}	{{RTO}}	{{RPO}}	{{الموقع}}	{{المزود}}	{{التاريخ}}
{{النظام 4}}	{{المالك}}	{{الفئة}}	{{RTO}}	{{RPO}}	{{الموقع}}	{{المزود}}	{{التاريخ}}

الجدول (16-7): الدعم الفني ومستويات الخدمة

الحقل	الوصف	القيمة المعبأة
قنوات الدعم المعتمدة		{{القنوات}}
ساعات تغطية الدعم		{{ساعات التغطية}}
نظام تتبع التذاكر المعتمد		{{نظام التتبع}}
قناة الإبلاغ عن الحوادث		{{قناة الحوادث}}
المستهدفات المعتمدة (P1–P4)	تُدرج من جدول 9.3 مع تعديلات الجهة	{{المستهدفات}}
جهة التصعيد الإداري		{{جهة التصعيد}}

الجدول (16-8): الأرشفة والسجلات

الحقل	الوصف	القيمة المعبأة
نظام الأرشفة/التخزين المعتمد		{{نظام الأرشفة}}
مسؤول الأرشيف والسجلات		{{مسؤول الأرشيف}}
مدة بقاء البريد في الصندوق الحي		{{مدة البقاء}}

الحقل	الوصف	القيمة المعبأة
مدة حفظ السجلات المالية		{{مدة السجلات المالية}}
مدة إضافية لسجلات الموافقات على البيانات		{{مدة الموافقات}}
موقع حفظ السجلات الضريبية	داخل المملكة	{{الموقع}}

الجدول (16-9): الذكاء الاصطناعي

الحقل	الوصف	القيمة المعبأة
مسؤول اعتماد أدوات الذكاء الاصطناعي		{{المسؤول}}
الأدوات المعتمدة وأغراضها		{{الأدوات المعتمدة}}
الأدوات المحظورة أو المعلقة		{{الأدوات المحظورة}}
سياسة إدخال البيانات في الأدوات العامة		{{سياسة الإدخال}}
فئة استخدام الجهة من الذكاء الاصطناعي	مساند أساسي/موسع	{{فئة الاستخدام}}

الجدول (16-10): الحوادث والامتثال والموردون

الحقل	الوصف	القيمة المعبأة
فريق الاستجابة للحوادث	الأسماء والأدوار والبدلاء	{{الفريق}}
مدة مراجعة ما بعد الحادث	أيام	{{مدة المراجعة}}
المتحدث الرسمي/الجهة المخولة بالحوادث		{{المتحدث}}
الموردون التقنيون الجوهريون وخدماتهم		{{الموردون}}
دورية مراجعة أداء الموردين		{{دورية المراجعة}}
مسؤول حماية البيانات (DPO) إن عيّنت الجهة		{{مسؤول الحماية}}
شركاء دعم خارجيون (عقود صيانة/استجابة)		{{الشركاء}}

قوائم الفحص التشغيلية (Operational Checklists)

تُستخدم هذه القوائم من فرق التقنية والأمن والإدارة للتحقق من اكتمال الالتزامات في المحطات الجوهرية. يُحفظ نموذج موقع من كل قائمة في الأرشيف، وتُدرج الملاحظات في خطط المعالجة.

قائمة الفحص (1): اعتماد نظام أو تطبيق جديد

#	البند	الحالة	المسؤول	التاريخ

#	البند	الحالة	المسؤول	التاريخ
1	توثيق الحاجة والغرض ومالك النظام	☐		
2	دراسة البدائل (اشتراك/تطوير/مشتركة) والتكلفة الكلية	☐		
3	تقييم أمن وخصوصية معتمد (البيانات، المواقع، النقل، حقوق الأفراد)	☐		
4	مراجعة الترخيص والملكية الفكرية وشروط المخرجات	☐		
5	التحقق من متطلبات الفوترة الإلكترونية والأرشفة عند الانطباق	☐		
6	إدراج شروط الأمن والاستمرارية والخروج في العقد	☐		
7	الاختبار (وظيفي/أمني/استرداد) وقبول مالك الخدمة	☐		
8	التسجيل في سجل الأصول وإصدار بطاقة نظام حرج عند الحرجية	☐		
9	خطة النسخ والاستمرارية وتفعيلها قبل الإطلاق	☐		
10	إخطار المستخدمين وتدريبهم وتوثيق دليل الاستخدام	☐		

قائمة الفحص (2): الجرد السنوي للأصول

#	البند	الحالة	المسؤول	التاريخ
1	تشكيل لجنة الجرد وتعيين مناطق المسؤولية	☐		
2	مطابقة السجل مع الأجهزة الموجودة فعليًا (أرقام تسلسلية)	☐		
3	مطابقة التراخيص بالمقاعد والاستخدام	☐		

#	البند	الحالة	المسؤول	التاريخ
	الفعلي			
4	مراجعة النطاقات والشهادات وتواريخ الانتهاء	☐		
5	مراجعة الحسابات والخدمات غير المستخدمة (تعطيل/إلغاء)	☐		
6	حصر الأصول التالفة والمفقودة ومعالجتها محاسبيًا وتقنيًا	☐		
7	تحديد الأصول المستحقة للإحلال وفق دورة الاستبدال	☐		
8	محضر الجرد وتوقيع اللجنة واعتماده	☐		
9	معالجة فروقات الجرد خلال المدة المعتمدة	☐		
10	تحديث سجل الأصول وخطط الاستمرارية بناءً على النتائج	☐		

قائمة الفحص (3): مراجعة الصلاحيات الربع السنوية

#	البند	الحالة	المسؤول	التاريخ
1	استخراج قوائم المستخدمين والصلاحيات من الأنظمة	☐		
2	مطابقة الحسابات مع كشوف الموظفين/المتطوعين الحاليين	☐		
3	إلغاء حسابات المنتهية علاقاتهم ونقل أو إعادة الصلاحيات	☐		
4	مراجعة الحسابات المميزة وتقليصها لأقل عدد ممكن	☐		
5	مراجعة حسابات الموردين والمقاولين	☐		

#	البند	الحالة	المسؤول	التاريخ
	(مدة/حاجة)			
6	التحقق من تفعيل MFA للنطاقات المشمولة	☐		
7	مراجعة صلاحيات الوصول إلى البيانات الحساسة	☐		
8	توثيق المراجعة والنتائج واعتمادها	☐		

قائمة الفحص (4): نشر تغيير تقني جوهري

#	البند	الحالة	المسؤول	التاريخ
1	اكتمال نموذج طلب التغيير وحقوله الإلزامية	☐		
2	تقييم الأثر والمخاطر والأمن والخصوصية	☐		
3	خطة اختبار ومعايير قبول موثقة	☐		
4	خطة رجوع قابلة للتنفيذ ومعايير تفعيلها	☐		
5	اعتماد CAB/الجهة المخولة وتوثيق القرار	☐		
6	نسخة احتياطية محدثة وقابلة للاستعادة قبل التنفيذ	☐		
7	إشعار المستخدمين قبل المدة المعتمدة	☐		
8	التنفيذ في نافذة معلنة واختبار ما بعد النشر	☐		
9	قبول مالك الخدمة ومراجعة ما بعد التنفيذ	☐		
10	تحديث سجل الأصول والإصدارات والتوثيق	☐		

قائمة الفحص (5): اختبار الاستعادة/التعافي

#	البند	الحالة	المسؤول	التاريخ

#	البند	الحالة	المسؤول	التاريخ
1	تحديد النظام والنطاق وسيناريو الاختبار المعتمد	☐		
2	توثيق RTO/RPO المستهدفة قبل الاختبار	☐		
3	تنفيذ الاستعادة من نسخة فعلية لا من الافتراض	☐		
4	قياس الزمن الفعلي واكتمال البيانات وسلامتها	☐		
5	التحقق من صلاحية التطبيقات والتكاملات بعد الاستعادة	☐		
6	توثيق النتائج في محضر اختبار استعادة (النموذج 6)	☐		
7	معالجة الفجوات وتحديد المسؤول والموعد	☐		
8	تحديث خطة الاستمرارية وخطط النسخ بناءً على النتائج	☐		

قائمة الفحص (6): الاستجابة لحادث تقني/أمني

#	البند	الحالة	المسؤول	التاريخ
1	تسجيل الحادث وتصنيف شدة وتحديد مدير الحادث	☐		
2	حماية الأدلة (لا حذف ولا تهيئة ولا إعادة تشغيل)	☐		
3	الاحتواء (عزل جهاز/تعطيل حساب/تعليق خدمة)	☐		
4	تقييم شمول البيانات الشخصية وتفعيل مسار الإخطار النظامي	☐		
5	الإخطار اللازم (سدايا خلال 72 ساعة عند انطباقه، الجهات	☐		

#	البند	الحالة	المسؤول	التاريخ
	المختصة)			
6	تفعيل خطة الاستمرارية والبدائل وقناة التواصل	☐		
7	الاستعادة والتحقق من السلامة	☐		
8	تحليل السبب الجذري وخطة المعالجة	☐		
9	مراجعة ما بعد الحادث وتقرير الإغلاق المعتمد	☐		
10	تحديث المخاطر والضوابط والتدريب بناءً على الدروس	☐		

قائمة الفحص (7): اعتماد أداة ذكاء اصطناعي

#	البند	الحالة	المسؤول	التاريخ
1	تحديد الغرض والفئة (محرمة/مشروطة/مسموحة)	☐		
2	التحقق من الجهة المطورة وموقع معالجة البيانات	☐		
3	مراجعة شروط الاحتفاظ بالمدخلات والتدريب عليها	☐		
4	مراجعة شروط ترخيص المخرجات والملكية الفكرية	☐		
5	تقييم مخاطر الخصوصية والتحيز والدقة	☐		
6	تحديد البيانات المسموح والممنوع إدخالها	☐		
7	دراسة البدائل (محلي/داخل المملكة) عند التكافؤ	☐		
8	اعتماد مسؤول بشري ومسار مراجعة مخرجات	☐		
9	تسجيل الأداة في سجل أدوات الذكاء الاصطناعي	☐		
10	توعية المستخدمين وإقراراتهم قبل التفعيل	☐		

قائمة الفحص (8): التعاقد مع مزود سحابي/مورد تقني

#	البند	الحالة	المسؤول	التاريخ
1	التحقق من التسجيل النظامي للمزود (هيئة الاتصالات والفضاء والتقنية)	☐		
2	تحديد مواقع مراكز البيانات والدعم والمقاولين من الباطن	☐		
3	تصنيف البيانات المستضافة ومراجعة اشتراطات إقامتها	☐		
4	مراجعة نموذج النسخ والاستعادة واختباره	☐		
5	إدراج SLA والأمن والحوادث والتدقيق في العقد	☐		
6	ضمان إرجاع البيانات بصيغ قابلة للاستخدام عند الإنهاء	☐		
7	دراسة نقل البيانات الشخصية عبر الحدود (المادة 29 واللائحة والـSCCs)	☐		
8	خطة الخروج والبدائل وعدم الاحتكار	☐		
9	موافقة مسؤول حماية البيانات والجهة المختصة	☐		

قائمة الفحص (9): إنهاء خدمة مستخدم/مقاول

#	البند	الحالة	المسؤول	التاريخ
1	إلغاء الحسابات والصلاحيات والوصول البعيد (فورًا)	☐		
2	استعادة الأجهزة والوسائط والمفاتيح والبطاقات	☐		
3	نقل الملفات والبريد والمسؤوليات إلى المالك الجديد	☐		

#	البند	الحالة	المسؤول	التاريخ
4	إلغاء صلاحيات الموردين والتطبيقات المرتبطة	☐		
5	تغيير الأسرار المشتركة والوصول الجماعي	☐		
6	الحذف الانتقائي من أجهزة BYOD وتوثيق إقراره	☐		
7	مراجعة توقيعات الإفصاح والالتزامات السارية	☐		
8	توثيق الإغلاق في محضر	☐		

قائمة الفحص (10): تفعيل جهاز شخصي (BYOD)

#	البند	الحالة	المسؤول	التاريخ
1	التحقق من أهلية الجهاز (إصدار نظام التشغيل، القفل)	☐		
2	توقيع نموذج موافقة BYOD وإقرار الاستخدام المقبول	☐		
3	تفعيل حاوية العمل/الفصل وتشفير بيانات العمل	☐		
4	تفعيل MFA وحل الأمن المطلوب	☐		
5	التحقق من عدم وجود بيانات حساسة مخزنة محليًا خارج الحاوية	☐		
6	تسجيل الجهاز في سجل الأجهزة المسموحة	☐		
7	تدريب المستخدم على الإبلاغ عن الفقدان	☐		

النماذج والاستمارات

النموذج (1): طلب تغيير تقني

┌──┐

│ {{اسم الجهة}} — طلب تغيير تقني رقم ( ) │

├──┤

│ بيانات الطلب: │

│ عنوان التغيير: _____ │

│ وصف التغيير: _____ │

│ المبرر/الغرض: _____ │

│ طالب التغيير: _____ المدير المباشر: _____ │

│ مالك الخدمة/النظام المتأثر: _____ │

│ تصنيف التغيير: ☐ قياسي ☐ عادي ☐ جوهري ☐ طارئ │

├──┤

│ التقييم: │

│ النطاق (أنظمة/خدمات/مستخدمون متأثرون): _____ │

│ الأثر المتوقع والمخاطر: _____ │

│ تقييم الأمن والخصوصية (عند الحاجة): _____ │

│ ☐ لا يمس بيانات شخصية ☐ يمس بيانات شخصية (تفصيل): _____ │

│ نافذة التنفيذ المقترحة: ____/____/_____ الوقت: _____ │

│ الإشعار للمستخدمين: قبل _____ أيام │

├──┤

│ الاختبار والقبول: │

│ خطة الاختبار: _____ │

│ معايير القبول: _____ │

│ نتائج الاختبار: _____ │

| خطة الرجوع: _____ |

| معايير تفعيل الرجوع: _____ |

| الاعتماد: |

| رأي الأمن/حماية البيانات: ☐ موافق ☐ موافق بشروط: _____ |

| توقيع: _____ التاريخ: ____/____/_____ |

| قرار لجنة التغيير/الجهة المخولة: ☐ اعتماد ☐ اعتماد مشروط |

| ☐ رفض (سبب): _____ توقيع: _____ التاريخ: ____ |

| التنفيذ والإغلاق: |

| تاريخ التنفيذ: ____/____/_____ المنجز: _____ |

| نتيجة ما بعد التنفيذ: ☐ ناجح ☐ رجع بالخطة ☐ فشل (حادث رقم: __) |

| قبول مالك الخدمة: _____ التاريخ: ____/____/_____ |

| مراجعة ما بعد التنفيذ (للجوهري): _____ |

| الدروس المستفادة/المعالجات: _____ |

| إغلاق الطلب بتاريخ: ____/____/_____ توقيع: _____ |

النموذج (2): تقرير حادث تقني/أمني

| {{اسم الجهة}} — تقرير حادث تقني رقم ( ) |

| بيانات الحادث: |

| تاريخ ووقت الاكتشاف: ____/____/_____ الساعة: _____ |

| طريقة الاكتشاف: ☐ بلاغ مستخدم ☐ مراقبة ☐ مورد ☐ أخرى: _____ |

| المبلِّغ (اختياري): _____ قناة البلاغ: _____ |

| التصنيف: ☐ تشغيلي ☐ أمني ☐ فقدان بيانات ☐ فقدان جهاز |

| الشدة: ☐ حرجة ☐ عالية ☐ متوسطة ☐ منخفضة |

| الأنظمة/الخدمات المتأثرة: _____ |

| عدد المتأثرين (مستفيدون/موظفون): _____ |

| وصف الحادث وخطورة الزمن: _____ |

|---|

| الاستجابة: |

| مدير الحادث: _____ أعضاء فريق الاستجابة: _____ |

| إجراءات الاحتواء: ☐ عزل جهاز ☐ تعطيل حساب ☐ تعليق خدمة |

| تفصيل: _____ |

| حفظ الأدلة: ☐ صور ☐ سجلات ☐ تواريخ (تفصيل): _____ |

| تفعيل خطة الاستمرارية/البديل: ☐ نعم (تفصيل): _____ |

|---|

| الإخطار النظامي: |

| ☐ يمس بيانات شخصية: إخطار سدايا بتاريخ/وقت: ____/____/_____ |

| ☐ أولي ☐ كامل ☐ إخطار الأشخاص المعنيين |

| ☐ بلاغ للجهات المختصة (جريمة معلوماتية): بتاريخ: _____ |

| ☐ إفصاح للمتعاملين: نطاقه: _____ بتاريخ: _____ |

| ☐ تواصل داخلي عبر: _____ المتحدث المعتمد: _____ |

|---|

| التعافي والتحليل: |

| تاريخ الاستعادة الكاملة: ____/____/_____ |

| السبب الجذري (RCA): _____ |

| الإجراءات الوقائية: _____ |

| المسؤول عن المعالجات والمواعيد: _____ |

| مراجعة ما بعد الحادث بتاريخ: ____/____/_____ |

| اعتماد الإغلاق: مالك الخدمة: _____ الأمن: _____ |

| الإدارة التنفيذية (عند الحوادث الحرجة): _____ |

└──┘

النموذج (3): نموذج جرد الأصول

┌──┐

| {{اسم الجهة}} — محضر جرد الأصول التقنية — سنة: _____ |

├──┤

| لجنة الجرد: الرئيس: _____ الأعضاء: _____ |

| نطاق الجرد: ☐ جميع الأصول ☐ عينات من: _____ |

| تاريخ بداية الجرد: ____/____/_____ نهايته: ____/____/_____ |

├──┤

| نتائج المطابقة: |

| الأصول المسجلة: _____ الموجودة فعلًا: _____ |

| المتطابقة: _____ الفروقات: _____ |

├──┤

| جدول الفروقات: |

| رقم الأصل | الوصف | الحالة | الإجراء | المسؤول |

|---|---|---|---|---|

| | | مفقود/تالف/زائد | | |

┌──────────┬──────────┬──────────┬──────────┬──────────┐
│ │
└──────────┴──────────┴──────────┴──────────┴──────────┘

┌──┐
│ مراجعة التراخيص والنطاقات: _____ │
│ الأصول المستحقة للإحلال: _____ │
│ المعالجات ومواعيدها: _____ │
│ توقيع لجنة الجرد: _____ اعتماد الإدارة: _____ │
└──┘

النموذج (4): بطاقة نظام حرج

الحقل	البيان
اسم النظام والمالك والخدمة والمستخدمون	.....
البيانات والتصنيف (شخصية/مالية/عادية) والمورد والموقع والمقاولون	.....
الإصدار والتكاملات والحسابات المميزة	.....
فئة الحرجية (1–4) ومستوى الخدمة وساعات الدعم والبديل	.....
RTO وRPO المعتمدان ومواقع النسخ ودورية اختبار الاستعادة	.....
الحوادث السابقة والتبعيات وخطة الخروج من المورد	.....
تاريخ آخر مراجعة وتاريخ المراجعة التالية والموافقات	.....

النموذج (5): موافقة استخدام جهاز شخصي (BYOD)

┌──┐
│ {{اسم الجهة}} — موافقة وإقرار استخدام جهاز شخصي للعمل │
└──┘

┌──┐
│ بيانات الموظف/المتطوع: │
│ الاسم: _____ الصفة: _____ القسم: _____ │
│ رقم الجوال: _____ طراز الجهاز: _____ │
│ إصدار نظام التشغيل: _____ هل الجهاز مقفل؟ ☐ نعم │

┌──┐

│ أقر أنا الموقع أدناه بأنني: │

│ 1- أستخدم جهازي الشخصي للعمل وفق ضوابط سياسة تقنية المعلومات │

│ المعتمدة، وبعد تفعيل حاوية العمل/الفصل التقني المعتمد. │

│ 2- أفهم أن بيانات العمل مشفرة ومفصولة، وأن الجهة تملك سلطة │

│ الحذف الانتقائي لبيانات العمل فقط عند الفقد أو السرقة أو │

│ انتهاء العلاقة، دون المساس ببياناتي الشخصية. │

│ 3- ألتزم بعدم الوصول عبر الجهاز إلى الأنظمة شديدة الحساسية أو │

│ تخزين بيانات المستفيدين أو المتبرعين محليًا خارج الحاوية. │

│ 4- ألتزم بحماية الجهاز (قفل وتحديث) والإبلاغ الفوري عن فقدانه │

│ خلال 24 ساعة كحد أقصى. │

│ التوقيع: _____ التاريخ: ____/____/_____ │

├──┤

│ للاستخدام الرسمي: │

│ تم تفعيل الحاوية والتشفير والـ MFA بتاريخ: ____/____/_____ │

│ تم تسجيل الجهاز في السجل برقم: _____ │

│ توقيع منسق التقنية: _____ │

├──┤

│ عند انتهاء العلاقة: │

│ تم الحذف الانتقائي لبيانات العمل بتاريخ: ____/____/_____ │

│ إقرار المستخدم: _____ توثيق التقنية: _____ │

└──┘

النموذج (6): محضر اختبار استعادة

الحقل	البيان
النظام/الخدمة ومالكها وسيناريو الاختبار	.....

الحقل	البيان
تاريخ ووقت الاختبار والمنفذ	.....
RTO المستهدف مقابل الفعلي (وقت الاستعادة)	.....
RPO المستهدف مقابل الفعلي (أحدث نقطة بيانات مستعادة)	.....
سلامة البيانات والتطبيقات والتكاملات بعد الاستعادة	.....
النتيجة: ناجح / ناجح بملاحظات / فاشل	.....
الفجوات والمعالجات (المسؤول/الموعد)	.....
التوصيات لتحديث خطة الاستمرارية/النسخ	.....
التوقيعات: المنفذ / مالك الخدمة / الأمن عند الحاجة	.....

الحواشي والمراجع

تنبيه تحققي: آخر تحقق رسمي من الروابط والمراجع تم بتاريخ إعداد هذا الإصدار (2026/11/06). يجب على مالك الوثيقة التحقق الدوري (كل 3 أشهر) من استمرار صلاحية الروابط وصدور تحديثات نظامية جديدة، وتحديث هذه القائمة وسجل التغييرات وفقًا لذلك.

#	المرجع	وصفه	الرابط/المصدر
1	نظام الجمعيات والمؤسسات الأهلية	المرسوم الملكي م/8 (1437/02/13 هـ) كما عُدِّل	/https://laws.boe.gov.sa
2	اللائحة التنفيذية لنظام الجمعيات والمؤسسات الأهلية	قرار مجلس الوزراء 833 (1442/12/24 هـ) كما عُدِّلت بالقرار 466 (1444/05/25 هـ)	https://ncnp.gov.sa
3	قواعد حوكمة الجمعيات والمؤسسات الأهلية	المركز الوطني (المعدلة)	https://ncnp.gov.sa
4	المعايير التشغيلية الإلزامية للمركز الوطني	كما تُحدَّث	https://ncnp.gov.sa
5	نظام حماية البيانات الشخصية	المرسوم الملكي م/19 (2021/09/16 م) كما عُدِّل	/https://sdaia.gov.sa + https://laws.boe.gov.sa

#	المرجع	وصفه	الرابط/المصدر
		بم/148 (1444/9/5هـ)	
6	اللائحة التنفيذية لنظام حماية البيانات الشخصية	القرار الإداري 1445/1516هـ -	https://sdaia.gov.sa
7	لائحة نقل البيانات الشخصية خارج المملكة	سدايا، المحدَّثة 2024/09/01م + البنود التعاقدية المعيارية (SCCs)	https://sdaia.gov.sa/en/DataPrivacySection
8	الدليل الإجرائي لإدارة حوادث اختراق البيانات الشخصية	سدايا (إخطار خلال 72 ساعة)	https://sdaia.gov.sa/en/SDAIA/about/Documents/PersonalDataBreachIncidents.pdf
9	مبادئ الذكاء الاصطناعي الأخلاقية السبعة	سدايا	https://sdaia.gov.sa
10	الضوابط الأساسية للأمن السيبراني ECC-2:2024	الهيئة الوطنية للأمن السيبراني	https://nca.gov.sa
11	ضوابط الأمن السيبراني للحوسبة السحابية CCC	الهيئة الوطنية للأمن السيبراني	https://nca.gov.sa
12	ضوابط الأمن السيبراني للأنظمة الحرجة CSCC	الهيئة الوطنية للأمن السيبراني	https://nca.gov.sa
13	قالب سياسة إدارة الحوادث والتهديدات السيبرانية	الهيئة الوطنية للأمن السيبراني	https://nca.gov.sa
14	نظام مكافحة الجرائم المعلوماتية	المرسوم الملكي م/17 1428/03/08) هـ)	/https://laws.boe.gov.sa

#	المرجع	وصفه	الرابط/المصدر
15	نظام المعاملات الإلكترونية	المرسوم الملكي م/18 كما عُدِّل بقرار مجلس الوزراء 293 (1445/04/09 هـ) + اللائحة التنفيذية	/https://mc.gov.sa + https://laws.boe.gov.sa
16	نظام الاتصالات وتقنية المعلومات	المرسوم الملكي م/106 (1443/11/02 هـ) + اللائحة التنفيذية (قرار وزاري 1444/13هـ)	https://www.cst.gov.sa
17	الإطار التنظيمي لحوسبة السحابة CCRF واللوائح المحدَّثة لتقديم خدمات الحوسبة السحابية	هيئة الاتصالات والفضاء والتقنية (أكتوبر 2023م)	https://www.cst.gov.sa
18	سياسة السحابة أولًا Cloud First Policy	هيئة الحكومة الرقمية	https://dga.gov.sa
19	اللائحة التنظيمية لتسجيل أسماء النطاقات تحت النطاق السعودي (sa.)	هيئة الاتصالات والفضاء والتقنية	https://www.cst.gov.sa
20	ضوابط الاتصالات التجارية عبر وسائل الاتصالات	هيئة الاتصالات والفضاء والتقنية	https://www.cst.gov.sa
21	نظام حقوق المؤلف الجديد ولائحته التنفيذية	المرسوم الملكي م/169 (1448هـ/ 2026م) + قرار مجلس	https://saip.gov.sa

#	المرجع	وصفه	الرابط/المصدر
		إدارة الهيئة السعودية للملكية الفكرية ت/33/2026	
22	نظام ضريبة القيمة المضافة ومتطلبات الفوترة الإلكترونية	الهيئة العامة للزكاة والضريبة والجمارك (منصة فاتورة)	https://zatca.gov.sa
23	نظام العمل السعودي ولائحته التنفيذية	وزارة الموارد البشرية والتنمية الاجتماعية (المادة 43: العمل عن بعد)	https://hrsd.gov.sa
24	نظام الأدلة السعودي	المرسوم الملكي م/43 1443/07/01) هـ)	/https://laws.boe.gov.sa
25	الإطار الوطني لإدارة البيانات	المكتب الوطني لإدارة البيانات (الأحكام المؤقتة)	https://dga.gov.sa
26	بوابة الخدمات الإلكترونية للمركز الوطني	التراخيص والتقارير	https://ncnp.gov.sa
27	منصات التعاقد والتبرعات الحكومية (نفاذ/إحسان/إتماد)	عند الارتباط بالجهات الحكومية	https://nafith.sa / https://ihsan.sa / https://etimad.sa
28	ISO/IEC 27001:2022 و ISO/IEC 1-20000 و ITIL 4 و ISO 22301	مراجع استئناسية دولية	https://www.iso.org
29	معايير التحول الرقمي الأساسية V3.0	هيئة الحكومة الرقمية (استئناسي)	https://dga.gov.sa

خاتمة الوثيقة

انتهت سياسة تقنية المعلومات وإدارة الخدمات الرقمية لـ«{{اسم الجهة}}» — الإصدار 3.0 بتاريخ 2026/11/06. تعتبر هذه النسخة نسخة العمل المعتمدة بعد استيفاء حقول التخصيص واعتماد الجهة المختصة، وتعمل بجانب سياسة أمن المعلومات وحماية البيانات ووثائق حزمة دفة الأخرى.

مالك الوثيقة: إدارة الحوكمة والسياسات — حزمة دفة المُطوَّرة

تاريخ المراجعة التالية: الربع الأخير من عام 2027م (أو فور صدور تعديل نظامي جوهري)